



2024/2690

18.10.2024

UITVOERINGSVERORDENING (EU) 2024/2690 VAN DE COMMISSIE

van 17 oktober 2024

tot vaststelling van regels voor de toepassing van Richtlijn (EU) 2022/2555 wat betreft de technische en methodologische vereisten van de maatregelen voor het beheer van cyberbeveiligingsrisico's en nadere specificatie van de gevallen waarin een incident als significant wordt beschouwd met betrekking tot DNS-dienstverleners, registers voor topleveldomeinnamen, aanbieders van cloudcomputingdiensten, aanbieders van datacentrumdiensten, aanbieders van netwerken voor de levering van inhoud, aanbieders van beheerde diensten, aanbieders van beheerde beveiligingsdiensten, aanbieders van onlinemarktplaatsen, van onlinezoekmachines en van platforms voor socialenetwerkdiensten, en verleners van vertrouwensdiensten

(Voor de EER relevante tekst)

DE EUROPESE COMMISSIE,

Gezien het Verdrag betreffende de werking van de Europese Unie,

Gezien Richtlijn (EU) 2022/2555 van het Europees Parlement en de Raad van 14 december 2022 betreffende maatregelen voor een hoog gezamenlijk niveau van cyberbeveiliging in de Unie, tot wijziging van Verordening (EU) nr. 910/2014 en Richtlijn (EU) 2018/1972 en tot intrekking van Richtlijn (EU) 2016/1148 (NIS 2-richtlijn) ⁽¹⁾, en met name artikel 21, lid 5, eerste alinea, en artikel 23, lid 11, tweede alinea,

Overwegende hetgeen volgt:

- (1) Met betrekking tot DNS-dienstverleners, registers voor topleveldomeinnamen, aanbieders van cloudcomputingdiensten, aanbieders van datacentrumdiensten, aanbieders van netwerken voor de levering van inhoud, aanbieders van beheerde diensten, aanbieders van beheerde beveiligingsdiensten, aanbieders van onlinemarktplaatsen, van onlinezoekmachines en van platforms voor socialenetwerkdiensten, en verleners van vertrouwensdiensten als bedoeld in artikel 3 van Richtlijn (EU) 2022/2555 (de relevante entiteiten), heeft deze verordening tot doel de technische en methodologische vereisten van de in artikel 21, lid 2, van Richtlijn (EU) 2022/2555 bedoelde maatregelen vast te stellen en de gevallen nader te specificeren waarin een incident als significant moet worden beschouwd in de zin van artikel 23, lid 3, van Richtlijn (EU) 2022/2555.
- (2) Rekening houdend met de grensoverschrijdende aard van hun activiteiten en met het oog op een samenhangend kader voor verleners van vertrouwensdiensten, moet in deze verordening met betrekking tot verleners van vertrouwensdiensten nader worden gespecificeerd in welke gevallen een incident als significant wordt beschouwd, naast de technische en methodologische vereisten van de maatregelen voor het beheer van cyberbeveiligingsrisico's.
- (3) Overeenkomstig artikel 21, lid 5, derde alinea, van Richtlijn (EU) 2022/2555 zijn de technische en methodologische vereisten van de maatregelen voor het beheer van cyberbeveiligingsrisico's in de bijlage bij deze verordening gebaseerd op Europese en internationale normen, zoals ISO/IEC 27001, ISO/IEC 27002 en ETSI EN 319401, en technische specificaties, zoals CEN/TS 18026:2024, die voor de beveiliging van netwerk- en informatiesystemen van belang zijn.
- (4) Inzake de uitvoering en toepassing van de technische en methodologische vereisten van de in de bijlage vastgestelde maatregelen voor het beheer van cyberbeveiligingsrisico's, moet overeenkomstig het evenredigheidsbeginsel rekening worden gehouden met de uiteenlopende risicoblootstellingen van relevante entiteiten, zoals het kritieke karakter van de relevante entiteit, de risico's waaraan zij is blootgesteld, de omvang en de structuur van de relevante entiteit, de waarschijnlijkheid van incidenten en de ernst ervan, met inbegrip van de maatschappelijke en economische gevolgen ervan, bij de naleving van de technische en methodologische vereisten van maatregelen voor het beheer van cyberbeveiligingsrisico's zoals uiteengezet in de bijlage.

⁽¹⁾ PB L 333 van 27.12.2022, blz. 80, ELI: <http://data.europa.eu/eli/dir/2022/2555/oj>.

- (5) Overeenkomstig het evenredigheidsbeginsel moeten relevante entiteiten, wanneer zij vanwege hun omvang bepaalde technische en methodologische vereisten van de maatregelen voor het beheer van cyberbeveiligingsrisico's niet kunnen uitvoeren, andere compenserende maatregelen kunnen nemen die geschikt zijn om het doel van die vereisten te verwezenlijken. Bij de vaststelling van rollen, verantwoordelijkheden en bevoegdheden voor de beveiliging van netwerk- en informatiesystemen binnen de relevante entiteit kan het voor micro-entiteiten bijvoorbeeld moeilijk zijn conflicterende taken en conflicterende verantwoordelijkheidsgebieden te scheiden. Dergelijke entiteiten moeten compenserende maatregelen kunnen overwegen, zoals gericht toezicht door het management van de entiteit of verscherpte monitoring en logging.
- (6) Bepaalde in de bijlage bij deze verordening opgenomen technische en methodologische vereisten moeten door de relevante entiteiten worden toegepast wanneer dit passend, indien van toepassing, of voor zover dit haalbaar is. Wanneer een relevante entiteit van oordeel is dat het voor haar niet passend, niet van toepassing of niet haalbaar is om bepaalde technische en methodologische vereisten als bedoeld in de bijlage bij deze verordening toe te passen, moet de relevante entiteit haar motivering dienaangaande op bevattelijke wijze documenteren. De nationale bevoegde autoriteiten kunnen bij de uitoefening van het toezicht rekening houden met de tijd die de relevante entiteiten nodig hebben om de technische en methodologische vereisten van de maatregelen voor het beheer van cyberbeveiligingsrisico's uit te voeren.
- (7) Het Agentschap van de Europese Unie voor cyberbeveiliging (Enisa) of de nationale bevoegde autoriteiten uit hoofde van Richtlijn (EU) 2022/2555 kunnen richtsnoeren verstrekken om relevante entiteiten te ondersteunen bij de identificatie, de analyse en de beoordeling van risico's met het oog op de uitvoering van de technische en methodologische vereisten voor de vaststelling en de instandhouding van een passend kader voor risicobeheer. Dergelijke richtsnoeren kunnen met name nationale en sectorale risicobeoordelingen omvatten, alsook risicobeoordelingen die specifiek zijn voor een bepaald type entiteit. De richtsnoeren kunnen ook instrumenten of modellen omvatten voor de ontwikkeling van een kader voor risicobeheer op het niveau van de relevante entiteiten. Kaders, richtsnoeren of andere mechanismen in de nationale wetgeving van de lidstaten en relevante Europese en internationale normen kunnen relevante entiteiten ook ondersteunen bij het aantonen van de naleving van deze verordening. Bovendien kunnen het Enisa of de nationale bevoegde autoriteiten uit hoofde van Richtlijn (EU) 2022/2555 relevante entiteiten ondersteunen bij het in kaart brengen en toepassen van passende oplossingen voor de behandeling van risico's die in dergelijke risicobeoordelingen zijn vastgesteld. Dergelijke richtsnoeren mogen geen afbreuk doen aan de verplichting van de relevante entiteiten om de risico's voor de beveiliging van netwerk- en informatiesystemen te bepalen en te documenteren, noch aan de verplichting van de relevante entiteiten om de technische en methodologische vereisten van de in de bijlage bij deze verordening uiteengezette maatregelen voor het beheer van cyberbeveiligingsrisico's toe te passen overeenkomstig hun behoeften en middelen.
- (8) Netwerkbeveiligingsmaatregelen met betrekking tot: i) de overgang naar communicatieprotocollen voor de recentste generatie netwerklaag, ii) de invoering van internationaal overeengekomen en interoperabele moderne e-mailcommunicatienormen, en iii) de toepassing van beste praktijken op het gebied van DNS-beveiliging en van routingbeveiliging en routinghygiëne op het internet brengen specifieke uitdagingen met zich mee met betrekking tot de vaststelling van de beste beschikbare normen en implementatietechnieken. Om zo spoedig mogelijk tot een hoog gezamenlijk niveau van cyberbeveiliging in alle netwerken te komen, moet de Commissie, bijgestaan door het Enisa en in samenwerking met de bevoegde autoriteiten, het bedrijfsleven — met inbegrip van de telecommunicatie-industrie — en andere belanghebbenden, de ontwikkeling ondersteunen van een multistakeholderforum dat tot taak heeft deze beste beschikbare normen en implementatietechnieken vast te stellen. Dergelijke richtsnoeren voor meerdere belanghebbenden mogen geen afbreuk doen aan de verplichting van de relevante entiteiten om de technische en methodologische vereisten van de in de bijlage bij deze verordening uiteengezette maatregelen voor het beheer van cyberbeveiligingsrisico's uit te voeren.
- (9) Overeenkomstig artikel 21, lid 2, punt a), van Richtlijn (EU) 2022/2555 moeten essentiële en belangrijke entiteiten, naast een beleid inzake risicoanalyse, een beleid inzake de beveiliging van informatiesystemen hebben. Daartoe moeten de relevante entiteiten een beleid inzake de beveiliging van netwerk- en informatiesystemen vaststellen, alsook themaspecifieke beleidsmaatregelen, zoals beleid inzake toegangscontrole, dat coherent moet zijn met het beleid inzake de beveiliging van netwerk- en informatiesystemen. Het beleid inzake de beveiliging van netwerk- en informatiesystemen moet het document op het hoogste niveau zijn waarin de algemene aanpak van de relevante entiteiten voor de beveiliging van netwerk- en informatiesystemen wordt uiteengezet, en door de bestuursorganen van de relevante entiteiten worden goedgekeurd. Het themaspecifieke beleid moet door een passend managementniveau worden goedgekeurd. In het beleid moeten indicatoren en maatregelen worden vastgesteld om de uitvoering ervan en de huidige status van het maturiteitsniveau van netwerk- en informatiebeveiliging van de relevante entiteiten te monitoren, met name om het toezicht op de uitvoering van de maatregelen voor het beheer van cyberbeveiligingsrisico's via de bestuursorganen te vergemakkelijken.

- (10) Voor de toepassing van de in de bijlage bij deze verordening vastgestelde technische en methodologische vereisten moet de term “gebruiker” alle natuurlijke en rechtspersonen omvatten die toegang hebben tot de netwerk- en informatiesystemen van de entiteit.
- (11) Om de risico's voor de veiligheid van netwerk- en informatiesystemen in kaart te brengen en aan te pakken, moeten de relevante entiteiten een passend kader voor risicobeheer vaststellen en handhaven. Als onderdeel van het kader voor risicobeheer moeten de relevante entiteiten een risicobehandelingsplan opstellen, uitvoeren en monitoren. De relevante entiteiten kunnen het risicobehandelingsplan gebruiken om opties en maatregelen voor risicobehandeling vast te stellen en te prioriteren. De opties voor risicobehandeling omvatten met name het vermijden, beperken of, in uitzonderlijke gevallen, aanvaarden van het risico. Bij de keuze van de risicobehandelingsopties moet rekening worden gehouden met de resultaten van de door de relevante entiteit uitgevoerde risicobeoordeling en moet het beleid van de relevante entiteit inzake de beveiliging van netwerk- en informatiesystemen worden nageleefd. Om uitvoering te geven aan de gekozen risicobehandelingsopties, moeten de relevante entiteiten passende risicobehandlingsmaatregelen nemen.
- (12) Om gebeurtenissen, bijna-incidenten en incidenten op te sporen, moeten de relevante entiteiten hun netwerk- en informatiesystemen monitoren en maatregelen nemen om gebeurtenissen, bijna-incidenten en incidenten te evalueren. Die maatregelen moeten het mogelijk maken om netwerkgebaseerde aanvallen op basis van afwijkend inkomend of uitgaand verkeer en DoS-aanvallen tijdig op te sporen.
- (13) Wanneer de relevante entiteiten een bedrijfsimpactanalyse uitvoeren, worden zij aangemoedigd een alomvattende analyse uit te voeren waarin, in voorkomend geval, de maximaal toelaatbare storingstijd en de doelstellingen inzake de hersteltijd, de herstelpunten en de dienstverlening worden vastgesteld.
- (14) Om de uit de toeleveringsketen van een relevante entiteit en haar betrekkingen met haar leveranciers voortvloeiende risico's te beperken, moeten de relevante entiteiten een beleid inzake de beveiliging van de toeleveringsketen vaststellen dat hun betrekkingen met hun directe leveranciers en dienstverleners regelt. Deze entiteiten moeten in de contracten met hun directe leveranciers of dienstverleners passende beveiligingsclausules opnemen, bijvoorbeeld door, waar passend, maatregelen voor het beheer van cyberbeveiligingsrisico's op te leggen overeenkomstig artikel 21, lid 2, van Richtlijn (EU) 2022/2555 of andere soortgelijke wettelijke vereisten.
- (15) De relevante entiteiten moeten regelmatig beveiligingstests uitvoeren op basis van een specifiek beleid en specifieke procedures om na te gaan of de maatregelen voor het beheer van cyberbeveiligingsrisico's worden uitgevoerd en naar behoren functioneren. Er kunnen beveiligingstests worden uitgevoerd op specifieke netwerk- en informatiesystemen of op de relevante entiteit als geheel, met inbegrip van geautomatiseerde of manuele tests, penetratietests, kwetsbaarheidsscans, statische en dynamische applicatiebeveiligingstests, configuratietests of beveiligingsaudits. De relevante entiteiten kunnen beveiligingstests op hun netwerk- en informatiesystemen uitvoeren bij het opzetten, na upgrades of wijzigingen van infrastructuur of applicaties die zij belangrijk achten, of na onderhoud. De bevindingen van de beveiligingstests moeten als basis dienen voor het beleid en de procedures van de relevante entiteiten om de doeltreffendheid van de risicobeheersmaatregelen op het gebied van cyberbeveiliging te beoordelen, alsook voor onafhankelijke evaluaties van hun netwerk- en informatiebeveiligingsbeleid.
- (16) Om aanzienlijke verstoringen en schade als gevolg van de exploitatie van niet-gepatchte kwetsbaarheden in netwerk- en informatiesystemen te voorkomen, moeten de relevante entiteiten passende procedures voor het beheer van beveiligingspatches vaststellen en toepassen die zijn afgestemd op het wijzigingsbeheer, het kwetsbaarheidsbeheer, het risicobeheer en andere relevante procedures van de relevante entiteiten. De relevante entiteiten moeten maatregelen nemen die in verhouding staan tot hun middelen om ervoor te zorgen dat beveiligingspatches geen extra kwetsbaarheden of onstabiele met zich meebrengen. In geval van geplande ontoegankelijkheid van de dienst als gevolg van de toepassing van beveiligingspatches, worden de relevante entiteiten aangemoedigd de klanten vooraf naar behoren te informeren.

- (17) De relevante entiteiten moeten de risico's beheren die voortvloeien uit de verwerving van ICT-producten of -diensten van leveranciers of aanbieders en moeten zekerheid verkrijgen dat de te verwerven ICT-producten of -diensten bepaalde niveaus van cyberbeveiligingsbescherming bereiken, bijvoorbeeld door middel van Europese cyberbeveiligingscertificaten en EU-conformiteitsverklaringen voor ICT-producten of -diensten die zijn afgegeven in het kader van een op grond van artikel 49 van Verordening (EU) 2019/881 van het Europees Parlement en de Raad vastgestelde Europese regeling voor cyberbeveiligingscertificering⁽⁷⁾. Wanneer de relevante entiteiten beveiligingsvereisten vaststellen die van toepassing zijn op de te verwerven ICT-producten, moeten zij rekening houden met de essentiële cyberbeveiligingsvereisten die zijn vastgesteld in een verordening van het Europees Parlement en de Raad betreffende horizontale cyberbeveiligingsvereisten voor producten met digitale elementen.
- (18) Om bescherming te bieden tegen cyberdreigingen en gegevensinbreuken te voorkomen en in te dammen, moeten de relevante entiteiten netwerkbeveiligingsoplossingen implementeren. Typische oplossingen voor netwerkbeveiliging omvatten het gebruik van firewalls om de interne netwerken van de relevante entiteiten te beschermen, de beperking van verbindingen en toegang tot diensten waar verbindingen en toegang absoluut nodig zijn, en het gebruik van virtuele particuliere netwerken voor toegang op afstand en het toestaan van aansluitingen van dienstverleners alleen na een verzoek om autorisatie en voor een bepaalde periode, zoals de duur van een onderhoudsactiviteit.
- (19) Om de netwerken van de relevante entiteiten en hun informatiesystemen te beschermen tegen kwaadwillige en niet-toegestane software, moeten die entiteiten controles uitvoeren die het gebruik van niet-toegestane software voorkomen of opsporen, en moeten zij, waar passend, software gebruiken voor opsporing en respons. De relevante entiteiten moeten ook maatregelen overwegen om het aanvalsoppervlak tot een minimum te beperken, kwetsbaarheden te verminderen die door aanvallers kunnen worden uitgebuit, de uitvoering van applicaties op eindpunten te controleren en e-mail- en webapplicatiefilters in te zetten om de blootstelling aan kwaadwillige inhoud te verminderen.
- (20) Op grond van artikel 21, lid 2, punt g), van Richtlijn (EU) 2022/2555 moeten de lidstaten ervoor zorgen dat essentiële en belangrijke entiteiten basispraktijken op het gebied van cyberhygiëne en opleiding op het gebied van cyberbeveiliging toepassen. Basispraktijken op het gebied van cyberhygiëne kunnen zero trust-beginselen, software-updates, configuratie van apparaten, netwerksegmentatie, identiteits- en toegangsbeheer of gebruikersbewustzijn omvatten, evenals opleidingen voor het personeel en moeten het bewustzijn op het gebied van cyberdreigingen, phishing of socialengineeringtechnieken vergroten. Praktijken op het gebied van cyberhygiëne maken deel uit van verschillende technische en methodologische vereisten van de in de bijlage vastgestelde maatregelen voor het beheer van cyberbeveiligingsrisico's. Wat basispraktijken op het gebied van cyberhygiëne voor gebruikers betreft, moeten de relevante entiteiten praktijken overwegen zoals een opgeruimd desk- en schermbeleid, het gebruik van multifactor- en andere authenticatiemiddelen, veilig e-mailgebruik en veilige webbrowsing, bescherming tegen phishing en social engineering, en beveiligde praktijken voor werken op afstand.
- (21) Om ongeoorloofde toegang tot de activa van de relevante entiteiten te voorkomen, moeten de relevante entiteiten een thematisch beleid vaststellen en uitvoeren dat betrekking heeft op de toegang voor personen en netwerk- en informatiesystemen, zoals toepassingen.
- (22) Om te voorkomen dat werknemers misbruik kunnen maken van bijvoorbeeld toegangsrechten binnen de relevante entiteit om schade te berokkenen, moeten de relevante entiteiten passende maatregelen voor personeelsbeheer overwegen en het personeel bewuster maken van dergelijke risico's. De relevante entiteiten moeten een tuchtprocedure vaststellen, bekendmaken en handhaven voor het omgaan met schendingen van het beveiligingsbeleid van de relevante entiteiten voor netwerk- en informatiesystemen, die kan worden ingebed in andere tuchtprocedures die door de relevante entiteiten zijn vastgesteld. Verificatie van de achtergrond van de werknemers en, waar van toepassing, de directe leveranciers en dienstverleners van de relevante entiteiten, moeten bijdragen aan de doelstelling van personeelsbeveiliging in de relevante entiteiten, en kunnen maatregelen omvatten zoals controles van het strafblad van de persoon of eerdere beroepstaken, al naargelang de taken van de persoon in de relevante entiteit en in overeenstemming met het beleid van de relevante entiteit inzake de beveiliging van netwerk- en informatiesystemen.

⁽⁷⁾ Verordening (EU) 2019/881 van het Europees Parlement en de Raad van 17 april 2019 inzake Enisa (het Agentschap van de Europese Unie voor cyberbeveiliging), en inzake de certificering van de cyberbeveiliging van informatie- en communicatietechnologie en tot intrekking van Verordening (EU) nr. 526/2013 (de cyberbeveiligingsverordening) (PB L 151 van 7.6.2019, blz. 15, ELI: <http://data.europa.eu/eli/reg/2019/881/oj>).

- (23) Multifactorauthenticatie kan de cyberbeveiliging van de entiteiten verbeteren en moet door de entiteiten in overweging worden genomen, met name wanneer gebruikers toegang op afstand hebben tot netwerk- en informatiesystemen, of wanneer zij toegang tot gevoelige informatie of bevoorrechte accounts en systeembeheeraccounts hebben. Multifactorauthenticatie kan worden gecombineerd met andere technieken om in specifieke omstandigheden aanvullende factoren te eisen, op basis van vooraf vastgestelde regels en patronen, zoals toegang vanaf een ongebruikelijke locatie, van een ongebruikelijk apparaat of op een ongebruikelijk tijdstip.
- (24) De relevante entiteiten moeten de activa die voor hen waardevol zijn, beheren en beschermen door middel van een degelijk activabeheer dat ook als basis moet dienen voor de risicoanalyse en het bedrijfscontinuïteitsbeheer. De relevante entiteiten moeten zowel materiële als immateriële activa beheren en een inventaris van de activa opstellen, de activa koppelen aan een bepaald classificatieniveau, de activa behandelen en volgen, en maatregelen nemen om de activa gedurende hun hele levenscyclus te beschermen.
- (25) Activabeheer moet inhouden dat activa worden ingedeeld naar type, gevoeligheid, risiconiveau en beveiligingsvereisten en dat passende maatregelen en controles worden toegepast om de beschikbaarheid, de integriteit, de vertrouwelijkheid en de authenticiteit ervan te waarborgen. Door activa naar risiconiveau in te delen, moeten de relevante entiteiten passende beveiligingsmaatregelen en -controles kunnen toepassen ter bescherming van activa, zoals encryptie, toegangscontrole, met inbegrip van controle van de perimeter en fysieke en logische toegang, backups, logging en monitoring, bewaring en verwijdering. Bij het uitvoeren van een bedrijfsimpactanalyse kunnen de relevante entiteiten het indelingsniveau bepalen op basis van de gevolgen van de verstoring van de activa voor de entiteiten. Alle werknemers van de entiteiten die met de activa werken, moeten vertrouwd zijn met het beleid en de instructies voor de behandeling van activa.
- (26) De granulariteit van de inventaris van activa moet afgestemd zijn op de behoeften van de relevante entiteiten. Een uitgebreide inventaris van activa kan voor elk actief ten minste een unieke identificatiecode omvatten, alsook de eigenaar van het actief, een beschrijving van het actief, de locatie van het actief, het type actief, het type en de classificatie van de in het actief verwerkte informatie, de datum van de laatste update of patch van het actief, de classificatie van het actief volgens de risicobeoordeling en het einde van de levensduur van het actief. Bij de identificatie van de eigenaar van een actief moeten de relevante entiteiten ook de persoon identificeren die verantwoordelijk is voor de bescherming van dat actief.
- (27) De toewijzing en de organisatie van rollen, verantwoordelijkheden en bevoegdheden op het gebied van cyberbeveiliging moeten zorgen voor een consistente structuur voor de governance en uitvoering van cyberbeveiliging binnen de relevante entiteiten, en voor doeltreffende communicatie in geval van incidenten. Bij het vaststellen en toewijzen van verantwoordelijkheden voor bepaalde rollen moeten de relevante entiteiten rekening houden met functies zoals hoofdinformatiebeveiligingsfunctionaris, informatiebeveiligingsfunctionaris, functionaris voor incidentenbehandeling, auditor of vergelijkbare equivalenten. De relevante entiteiten kunnen taken en verantwoordelijkheden toewijzen aan externe partijen, zoals derde aanbieders van ICT-diensten.
- (28) Overeenkomstig artikel 21, lid 2, van Richtlijn (EU) 2022/2555 moeten de maatregelen voor het beheer van cyberbeveiligingsrisico's gebaseerd zijn op een benadering die alle gevaren omvat en tot doel heeft netwerk- en informatiesystemen en de fysieke omgeving van die systemen te beschermen tegen gebeurtenissen die de beschikbaarheid, de authenticiteit, de integriteit of de vertrouwelijkheid van opgeslagen, verzonden of verwerkte gegevens of van de diensten die door of via netwerk- en informatiesystemen worden aangeboden, in gevaar kunnen brengen, zoals diefstal, brand, overstromingen en telecommunicatie- en stroomstoringen of ongeoorloofde fysieke toegang tot, beschadiging van of interferentie met de informatie- en informatieverwerkingsfaciliteiten van een essentiële of belangrijke entiteit. Bij de technische en methodologische vereisten van de maatregelen voor het beheer van cyberbeveiligingsrisico's moet daarom ook aandacht worden besteed aan de fysieke en omgevingsbeveiliging van netwerk- en informatiesystemen door maatregelen op te nemen om dergelijke systemen te beschermen tegen systeemstoringen, menselijke fouten, kwaadaardige handelingen of natuurverschijnselen. Andere voorbeelden van fysieke en omgevingsdreigingen zijn aardbevingen, explosies, sabotage, dreiging van binnenuit, onlusten, giftig afval en emissies in het milieu. Het voorkomen van verlies, beschadiging of compromittering van netwerk- en informatiesystemen of de onderbreking van hun werking als gevolg van het falen of de verstoring van ondersteunende nutsbedrijven moet bijdragen tot het doel van bedrijfscontinuïteit in de relevante entiteiten. Bovendien moet bescherming tegen fysieke en omgevingsdreigingen bijdragen tot de beveiliging van het onderhoud van netwerk- en informatiesystemen in de relevante entiteiten.

- (29) Relevante entiteiten moeten beschermingsmaatregelen tegen fysieke en omgevingsdreigingen ontwerpen en implementeren en minimum- en maximumcontroledrempels voor fysieke en omgevingsdreigingen bepalen en omgevingsparameters bewaken. Zij moeten bijvoorbeeld overwegen systemen te installeren om in een vroeg stadium te detecteren of gebieden waar netwerk- en informatiesystemen zich bevinden, overstroomd. Met betrekking tot brandgevaar moeten de relevante entiteiten overwegen om een apart brandcompartiment voor het datacentrum in te richten, brandwerende materialen te gebruiken, sensoren voor het monitoren van temperatuur en vochtigheid te gebruiken, het gebouw aan te sluiten op een brandalarmsysteem met een automatische melding aan de lokale brandweer, en systemen voor vroegtijdige branddetectie en -blussing te installeren. De relevante entiteiten moeten ook regelmatige brandoefeningen en brandinspecties uitvoeren. Om de stroomvoorziening te waarborgen, moeten de relevante entiteiten bovendien overspanningsbeveiliging en de bijbehorende noodstroomvoorziening in overweging nemen, in overeenstemming met de desbetreffende normen. Aangezien oververhitting een risico vormt voor de beschikbaarheid van netwerk- en informatiesystemen, kunnen relevante entiteiten, met name aanbieders van datacentrumdiensten, bovendien passende, continue en redundante airconditioningsystemen overwegen.
- (30) In deze verordening wordt nader gespecificeerd in welke gevallen een incident als significant moet worden beschouwd voor de toepassing van artikel 23, lid 3, van Richtlijn (EU) 2022/2555. De criteria moeten de relevante entiteiten in staat stellen om te beoordelen of een incident significant is, teneinde het incident overeenkomstig Richtlijn (EU) 2022/2555 te melden. Voorts moeten de in deze verordening vastgestelde criteria als uitputtend worden beschouwd, onverminderd artikel 5 van Richtlijn (EU) 2022/2555. Deze verordening specificeert de gevallen waarin een incident als significant moet worden beschouwd door zowel horizontale als entiteitsspecifieke gevallen vast te stellen.
- (31) Overeenkomstig artikel 23, lid 4, van Richtlijn (EU) 2022/2555 moeten de relevante entiteiten significante incidenten melden binnen de in die bepaling vastgestelde termijnen. Deze meldingstermijnen gaan in op het moment dat de entiteit kennis heeft gekregen van dergelijke significante incidenten. De relevante entiteit is daarom verplicht om incidenten te melden die, op basis van haar eerste beoordeling, ernstige operationele verstoring van de diensten of financieel verlies voor die entiteit zouden kunnen veroorzaken of andere natuurlijke of rechtspersonen zouden kunnen treffen door aanzienlijke materiële of immateriële schade te veroorzaken. Wanneer een relevante entiteit een verdachte gebeurtenis heeft gedetecteerd, of nadat een mogelijk incident onder haar aandacht is gebracht door een derde partij, zoals een individu, een klant, een entiteit, een autoriteit, een mediaorganisatie of een andere bron, moet de relevante entiteit daarom tijdig de verdachte gebeurtenis beoordelen om te bepalen of het een incident is en, zo ja, de aard en ernst ervan bepalen. De relevante entiteit moet daarom worden geacht "op de hoogte" te zijn van het significante incident wanneer die entiteit, na een dergelijke eerste beoordeling, een redelijke mate van zekerheid heeft dat zich een significant incident heeft voorgedaan.
- (32) Om vast te stellen of een incident significant is, moeten relevante entiteiten in voorkomend geval het aantal door het incident getroffen gebruikers tellen, rekening houdend met zakelijke en eindklanten waarmee de relevante entiteiten een contractuele relatie hebben en met natuurlijke en rechtspersonen die banden hebben met zakelijke klanten. Wanneer een relevante entiteit niet in staat is het aantal getroffen gebruikers te berekenen, moet bij de berekening van het totale aantal door het incident getroffen gebruikers rekening worden gehouden met de schatting van de relevante entiteit van het mogelijke maximale aantal getroffen gebruikers. Het belang van een incident waarbij een vertrouwensdienst betrokken is, moet niet alleen worden bepaald door het aantal gebruikers, maar ook door het aantal vertrouwende partijen, aangezien deze in gelijke mate kunnen worden getroffen door een significant incident waarbij een vertrouwensdienst betrokken is met betrekking tot operationele verstoringen en materiële of immateriële schade. Daarom moeten verleners van vertrouwensdiensten, indien van toepassing, ook rekening houden met het aantal vertrouwende partijen wanneer zij vaststellen of een incident significant is. Daartoe moeten vertrouwende partijen worden opgevat als natuurlijke of rechtspersonen die een beroep doen op een vertrouwensdienst.
- (33) Onderhoudswerkzaamheden die leiden tot beperkte beschikbaarheid of niet-beschikbaarheid van de diensten mogen niet als significante incidenten worden beschouwd indien de beperkte beschikbaarheid of niet-beschikbaarheid van de dienst plaatsvindt volgens een geplande onderhoudsactiviteit. Wanneer een dienst niet beschikbaar is als gevolg van geplande onderbrekingen, zoals onderbrekingen of niet-beschikbaarheid op basis van een vooraf bepaalde contractuele overeenkomst, mag dit ook niet als een significant incident worden beschouwd.

- (34) De duur van een incident dat van invloed is op de beschikbaarheid van een dienst, moet worden gemeten vanaf de verstoring van de juiste verlening van die dienst tot het moment van herstel. Wanneer een relevante entiteit niet in staat is het tijdstip te bepalen waarop de verstoring begon, moet de duur van het incident worden gemeten vanaf het moment waarop het incident werd ontdekt of vanaf het moment waarop het incident werd geregistreerd in netwerk- of systeemlogbestanden of andere gegevensbronnen, indien dat eerder is.
- (35) De volledige onbeschikbaarheid van een dienst moet worden gemeten vanaf het moment waarop de dienst volledig onbeschikbaar is voor gebruikers tot het moment waarop de reguliere werking of activiteiten zijn hersteld tot het serviceniveau dat vóór het incident werd verleend. Wanneer een relevante entiteit niet in staat is te bepalen wanneer de volledige niet-beschikbaarheid van een dienst begon, moet de niet-beschikbaarheid worden gemeten vanaf het moment dat dit door die entiteit werd gedetecteerd.
- (36) Om de directe financiële verliezen als gevolg van een incident te bepalen, moeten de relevante entiteiten rekening houden met alle financiële verliezen die zij als gevolg van het incident hebben geleden, zoals kosten voor de vervanging of verplaatsing van software, hardware of infrastructuur, personeelskosten, met inbegrip van kosten in verband met de vervanging of verplaatsing van personeel, de aanwerving van extra personeel, de vergoeding van overuren en het herstel van verloren of beperkte vaardigheden, vergoedingen wegens niet-naleving van contractuele verplichtingen, kosten voor schadeloosstelling en compensatie van klanten, verliezen als gevolg van gederfde inkomsten, kosten in verband met interne en externe communicatie, advieskosten, met inbegrip van kosten in verband met juridisch advies, forensische diensten en hersteldiensten, en andere kosten in verband met het incident. Administratieve geldboeten, evenals kosten die nodig zijn voor de dagelijkse bedrijfsvoering van het bedrijf, mogen echter niet worden beschouwd als financiële verliezen als gevolg van een incident, met inbegrip van kosten voor algemeen onderhoud van infrastructuur, uitrusting, hardware en software, het actueel houden van de vaardigheden van het personeel, interne of externe kosten om het bedrijf na het incident te verbeteren, met inbegrip van upgrades, verbeterings- en risicobeoordelingsinitiatieven, en verzekeringspremies. De relevante entiteiten moeten de bedragen van de financiële verliezen berekenen op basis van de beschikbare gegevens en wanneer de werkelijke bedragen van de financiële verliezen niet kunnen worden bepaald, moeten de entiteiten die bedragen ramen.
- (37) De relevante entiteiten moeten ook worden verplicht incidenten te melden die de dood van natuurlijke personen of aanzienlijke schade aan de gezondheid van natuurlijke personen hebben veroorzaakt of kunnen veroorzaken, aangezien dergelijke incidenten bijzonder ernstige gevallen van aanzienlijke materiële of immateriële schade zijn. Een incident dat een relevante entiteit treft, kan bijvoorbeeld de onbeschikbaarheid van gezondheidszorg of nooddiensten veroorzaken, of het verlies van de vertrouwelijkheid of integriteit van gegevens met gevolgen voor de gezondheid van natuurlijke personen. Om te bepalen of een incident aanzienlijke schade aan de gezondheid van een natuurlijke persoon heeft veroorzaakt of kan veroorzaken, moeten de relevante entiteiten rekening houden met de vraag of het incident ernstige verwondingen en gezondheidsproblemen heeft veroorzaakt of kan veroorzaken. Daartoe mag van de betrokken entiteiten niet worden verlangd dat zij aanvullende informatie verzamelen waartoe zij geen toegang hebben.
- (38) Beperkte beschikbaarheid moet met name worden geacht plaats te vinden wanneer een door een relevante entiteit verleende dienst aanzienlijk trager is dan de gemiddelde responstijd, of wanneer niet alle functies van een dienst beschikbaar zijn. Waar mogelijk moeten objectieve criteria op basis van de gemiddelde responstijden van de door de relevante entiteiten verleende diensten worden gebruikt om vertragingen in de responstijd te beoordelen. Een functionaliteit van een dienst kan bijvoorbeeld een chatfunctie of een zoekfunctie voor afbeeldingen zijn.
- (39) Succesvolle, vermoedelijk kwaadwillige en ongeoorloofde toegang tot de netwerk- en informatiesystemen van een relevante entiteit moet worden beschouwd als een significant incident, wanneer een dergelijke toegang ernstige operationele verstoringen kan veroorzaken. Wanneer een actor van cyberdreiging zich bijvoorbeeld vooraf in de netwerk- en informatiesystemen van een relevante entiteit positioneert met de bedoeling om in de toekomst een verstoring van de dienstverlening te veroorzaken, moet het incident als significant worden beschouwd.

- (40) Terugkerende incidenten die verband houden met dezelfde kennelijk onderliggende oorzaak, die afzonderlijk niet aan de criteria van een significant incident voldoen, moeten gezamenlijk worden beschouwd als een significant incident, op voorwaarde dat zij gezamenlijk aan het criterium voor financieel verlies voldoen en dat zij zich binnen zes maanden ten minste twee keer hebben voorgedaan. Dergelijke terugkerende incidenten kunnen wijzen op aanzienlijke tekortkomingen en zwakke punten in de risicobeheerprocedures voor cyberbeveiliging van de relevante entiteit en haar maturiteitsniveau op het gebied van cyberbeveiliging. Bovendien kunnen dergelijke terugkerende incidenten aanzienlijke financiële verliezen veroorzaken voor de relevante entiteit.
- (41) De Commissie heeft advies uitgewisseld en samengewerkt met de samenwerkingsgroep en het Enisa rond de ontwerpuitvoeringshandeling, overeenkomstig artikel 21, lid 5, en artikel 23, lid 11, van Richtlijn (EU) 2022/2555.
- (42) De Europese Toezichthouder voor gegevensbescherming is overeenkomstig artikel 42, lid 1, van Verordening (EU) 2018/1725 van het Europees Parlement en de Raad ⁽⁹⁾ geraadpleegd en heeft op 1 september 2024 een advies uitgebracht.
- (43) De in deze verordening vervatte maatregelen zijn in overeenstemming met het advies van het bij artikel 39 van Richtlijn (EU) 2022/2555 ingestelde comité,

HEEFT DE VOLGENDE VERORDENING VASTGESTELD:

Artikel 1

Onderwerp

Met betrekking tot DNS-dienstverleners, registers voor topleveldomeinnamen, aanbieders van cloudcomputingdiensten, aanbieders van datacentrumdiensten, aanbieders van netwerken voor de levering van inhoud, aanbieders van beheerde diensten, aanbieders van beheerde beveiligingsdiensten, aanbieders van onlinemarktplaatsen, van onlinezoekmachines en van platforms voor socialenetwerkdiensten, en verleners van vertrouwensdiensten (de relevante entiteiten) worden in deze verordening de technische en methodologische vereisten van de in artikel 21, lid 2, van Richtlijn (EU) 2022/2555 bedoelde maatregelen vastgesteld en worden de gevallen gespecificeerd waarin een incident als significant wordt beschouwd in de zin van artikel 23, lid 3, van Richtlijn (EU) 2022/2555.

Artikel 2

Technische en methodologische vereisten

1. Voor de relevante entiteiten zijn de technische en methodologische vereisten voor de in artikel 21, lid 2, punten a) tot en met j), van Richtlijn (EU) 2022/2555 bedoelde maatregelen voor het beheer van cyberbeveiligingsrisico's vastgesteld in de bijlage.
2. De relevante entiteiten zorgen voor een beveiligingsniveau van netwerk- en informatiesystemen dat passend is voor de risico's die zich voordoen bij de uitvoering en de toepassing van de technische en methodologische vereisten van de in de bijlage bij deze verordening uiteengezette maatregelen voor het beheer van cyberbeveiligingsrisico's. Daartoe houden zij naar behoren rekening met de mate van blootstelling aan risico's, hun omvang en de waarschijnlijkheid van incidenten en de ernst ervan, met inbegrip van hun maatschappelijke en economische gevolgen, wanneer zij aan de technische en methodologische vereisten van de in de bijlage vastgestelde maatregelen voor het beheer van cyberbeveiligingsrisico's voldoen. Indien in de bijlage bij deze verordening is bepaald dat een technische of methodologische vereiste van een risicobeheersmaatregel op het gebied van cyberbeveiliging "waar passend", "indien van toepassing" of "voor zover haalbaar" moet worden toegepast, en indien een relevante entiteit van mening is dat het niet passend, niet van toepassing of niet haalbaar is voor de relevante entiteit om bepaalde van dergelijke technische en methodologische vereisten toe te passen, documenteert de relevante entiteit haar motivering ter zake op begrijpelijke wijze.

⁽⁹⁾ Verordening (EU) 2018/1725 van het Europees Parlement en de Raad van 23 oktober 2018 betreffende de bescherming van natuurlijke personen in verband met de verwerking van persoonsgegevens door de instellingen, organen en instanties van de Unie en betreffende het vrije verkeer van die gegevens, en tot intrekking van Verordening (EG) nr. 45/2001 en Besluit nr. 1247/2002/EG (PB L 295 van 21.11.2018, blz. 39, ELI: <http://data.europa.eu/eli/reg/2018/1725/oj>).

Indien in de bijlage bij deze verordening is bepaald dat een technische of methodologische vereiste van een risicobeheersmaatregel op het gebied van cyberbeveiliging “waar passend”, “indien van toepassing” of “voor zover haalbaar” moet worden toegepast, en indien een relevante entiteit van mening is dat het niet passend, niet van toepassing of niet haalbaar is voor de relevante entiteit om bepaalde van dergelijke technische en methodologische vereisten toe te passen, documenteert de relevante entiteit haar motivering ter zake op begrijpelijke wijze.

Artikel 3

Significante incidenten

1. Een incident wordt voor de toepassing van artikel 23, lid 3, van Richtlijn (EU) 2022/2555 met betrekking tot de relevante entiteiten als significant beschouwd indien aan een of meer van de volgende criteria is voldaan:
 - a) het incident heeft voor de relevante entiteit direct financieel verlies veroorzaakt of kan verlies veroorzaken dat hoger is dan 500 000 EUR of meer dan 5 % van de totale jaaromzet van de relevante entiteit in het voorgaande boekjaar, indien dat lager is;
 - b) het incident heeft het uitlekken van bedrijfsgeheimen als bedoeld in artikel 2, punt 1, van Richtlijn (EU) 2016/943 van de relevante entiteit veroorzaakt of kan dit veroorzaken;
 - c) het incident heeft de dood van een natuurlijke persoon veroorzaakt of kan dit veroorzaken;
 - d) het incident heeft aanzienlijke schade aan de gezondheid van een natuurlijke persoon veroorzaakt of kan dit veroorzaken;
 - e) er heeft een succesvolle, vermoedelijk kwaadwillige en ongeoorloofde toegang tot netwerk- en informatiesystemen plaatsgevonden, die ernstige operationele verstoringen kan veroorzaken;
 - f) het incident voldoet aan de criteria van artikel 4;
 - g) het incident voldoet aan een of meer van de criteria van de artikelen 5 tot en met 14.
2. Geplande dienstonderbrekingen en geplande gevolgen van geplande onderhoudswerkzaamheden die door of namens de relevante entiteiten worden uitgevoerd, worden niet als significante incidenten beschouwd.
3. Bij de berekening van het aantal gebruikers dat door een incident wordt getroffen voor de toepassing van de artikelen 7 en 9 tot en met 14, houden de relevante entiteiten rekening met onderstaande punten:
 - a) het aantal klanten dat op basis van een overeenkomst met de relevante entiteit toegang heeft tot haar netwerk- en informatiesystemen of tot diensten van de relevante entiteit die worden aangeboden door of toegankelijk zijn via die netwerk- en informatiesystemen;
 - b) het aantal met zakelijke klanten verbonden natuurlijke en rechtspersonen die gebruikmaken van de netwerk- en informatiesystemen of van diensten van de entiteiten die worden aangeboden door of toegankelijk zijn via die netwerk- en informatiesystemen.

Artikel 4

Terugkerende incidenten

Incidenten die afzonderlijk niet als een significant incident in de zin van artikel 3 worden beschouwd, worden gezamenlijk als één significant incident beschouwd indien zij aan alle volgende criteria voldoen:

- a) zij hebben zich ten minste tweemaal binnen zes maanden voorgedaan;
- b) zij hebben dezelfde kennelijk onderliggende oorzaak;
- c) zij voldoen gezamenlijk aan de criteria van artikel 3, lid 1, punt a).

*Artikel 5***Significante incidenten met betrekking tot DNS-dienstverleners**

Met betrekking tot DNS-dienstverleners wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een recursieve of gezaghebbende domeinnaamomzettingsdienst is meer dan 30 minuten volledig onbeschikbaar;
- b) gedurende meer dan een uur bedraagt de gemiddelde responstijd van een recursieve of gezaghebbende domeinnaamomzettingsdienst op DNS-verzoeken meer dan 10 seconden;
- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van de gezaghebbende domeinnaamomzettingsdienst is aangetast, behalve in gevallen waarin de gegevens van minder dan 1 000 domeinnamen die door de DNS-dienstverlener worden beheerd en die niet meer dan 1 % uitmaken van de domeinnamen die door de DNS-dienstverlener worden beheerd, niet correct zijn als gevolg van een verkeerde configuratie.

*Artikel 6***Significante incidenten met betrekking tot registers voor topleveldomeinnamen**

Met betrekking tot registers voor topleveldomeinnamen wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een gezaghebbende domeinnaamomzettingsdienst is volledig onbeschikbaar;
- b) gedurende meer dan een uur bedraagt de gemiddelde responstijd van een gezaghebbende domeinnaamomzettingsdienst op DNS-verzoeken meer dan 10 seconden;
- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de technische exploitatie van het topleveldomein is aangetast.

*Artikel 7***Significante incidenten met betrekking tot aanbieders van cloudcomputingdiensten**

Met betrekking tot aanbieders van cloudcomputingdiensten wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een geleverde cloudcomputingdienst is meer dan 30 minuten volledig niet beschikbaar;
- b) de beschikbaarheid van een cloudcomputingdienst van een aanbieder is gedurende meer dan één uur beperkt voor meer dan 5 % van de gebruikers van de cloudcomputingdienst in de Unie, of voor meer dan 1 miljoen gebruikers van de cloudcomputingdienst in de Unie, afhankelijk van welk aantal het kleinste is;
- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een cloudcomputingdienst is aangetast als gevolg van een vermoedelijk kwaadwillige handeling;
- d) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een cloudcomputingdienst is aangetast, met gevolgen voor meer dan 5 % van de gebruikers de cloudcomputingdienst in de Unie, of voor meer dan 1 miljoen gebruikers van de cloudcomputingdienst in de Unie, afhankelijk van welk aantal het kleinste is.

*Artikel 8***Significante incidenten met betrekking tot aanbieders van datacentrumdiensten**

Met betrekking tot aanbieders van datacentrumdiensten wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een datacentrumdienst van een door de aanbieder beheerd datacentrum is volledig onbeschikbaar;
- b) de beschikbaarheid van een datacentrumdienst van een datacentrum dat door de aanbieder wordt geëxploiteerd, is meer dan één uur beperkt;

- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een datacentrumdienst is aangetast als gevolg van een vermoedelijk kwaadwillige handeling;
- d) de fysieke toegang tot een door de aanbieder geëxploiteerd datacentrum is gecompromitteerd.

Artikel 9

Significante incidenten met betrekking tot aanbieders van netwerken voor de levering van inhoud

Met betrekking tot aanbieders van netwerken voor de levering van inhoud wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een netwerk voor de levering van inhoud is gedurende meer dan 30 minuten volledig niet beschikbaar;
- b) de beschikbaarheid van een netwerk voor de levering van inhoud is gedurende meer dan één uur beperkt voor meer dan 5 % van de gebruikers van het netwerk voor de levering van inhoud in de Unie, of voor meer dan 1 miljoen van de gebruikers van het netwerk voor de levering van inhoud in de Unie, afhankelijk van welk aantal het kleinste is;
- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een netwerk voor de levering van inhoud is aangetast als gevolg van een vermoedelijk kwaadwillige handeling;
- d) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een netwerk voor de levering van inhoud is aangetast, met gevolgen voor meer dan 5 % van de gebruikers van een netwerk voor de levering van inhoud in de Unie, of voor meer dan 1 miljoen gebruikers van een netwerk voor de levering van inhoud in de Unie, afhankelijk van welk aantal het kleinste is.

Artikel 10

Significante incidenten met betrekking tot aanbieders van beheerde diensten en aanbieders van beheerde beveiligingsdiensten

Met betrekking tot aanbieders van beheerde diensten en aanbieders van beheerde beveiligingsdiensten wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een beheerde dienst of beheerde beveiligingsdienst is gedurende meer dan 30 minuten volledig onbeschikbaar;
- b) de beschikbaarheid van een beheerde dienst of beheerde beveiligingsdienst is gedurende meer dan één uur beperkt voor meer dan 5 % van de gebruikers van de dienst in de Unie, of voor meer dan 1 miljoen van de gebruikers van de dienst in de Unie, afhankelijk van welk aantal het kleinste is;
- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een beheerde dienst of beheerde beveiligingsdienst is aangetast als gevolg van een vermoedelijk kwaadwillige handeling;
- d) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een beheerde dienst of een beheerde beveiligingsdienst is aangetast, met gevolgen voor meer dan 5 % van de gebruikers van een beheerde dienst of een beheerde beveiligingsdienst in de Unie, of voor meer dan 1 miljoen van de gebruikers van de dienst in de Unie, afhankelijk van welk aantal het kleinste is.

Artikel 11

Significante incidenten met betrekking tot aanbieders van onlinemarktplaatsen

Met betrekking tot aanbieders van onlinemarktplaatsen wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien het voldoet aan een of meer van de volgende criteria:

- a) een onlinemarktplaats is volledig niet beschikbaar voor meer dan 5 % van de gebruikers van een onlinemarktplaats in de Unie, of voor meer dan 1 miljoen gebruikers van een onlinemarktplaats in de Unie, afhankelijk van welk aantal het kleinste is;

- b) meer dan 5 % van de gebruikers van een onlinemarktplaats in de Unie, of meer dan 1 miljoen gebruikers van een onlinemarktplaats in de Unie, afhankelijk van welk aantal het kleinste is, worden getroffen door de beperkte beschikbaarheid van die onlinemarktplaats;
- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een onlinemarktplaats is aangetast als gevolg van een vermoedelijk kwaadwillige handeling;
- d) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een onlinemarktplaats is aangetast, met gevolgen voor meer dan 5 % van de gebruikers van een onlinemarktplaats in de Unie, of voor meer dan 1 miljoen gebruikers van een onlinemarktplaats in de Unie, afhankelijk van welk aantal het kleinste is.

Artikel 12

Significante incidenten met betrekking tot aanbieders van onlinezoekmachines

Met betrekking tot aanbieders van onlinezoekmachines wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een onlinezoekmachine is volledig niet beschikbaar voor meer dan 5 % van de gebruikers van die onlinezoekmachine in de Unie, of voor meer dan 1 miljoen gebruikers van die onlinezoekmachine in de Unie, afhankelijk van welk aantal het kleinste is;
- b) meer dan 5 % van de gebruikers van een onlinezoekmachine in de Unie, of meer dan 1 miljoen gebruikers van een onlinezoekmachine in de Unie, afhankelijk van welk aantal het kleinste is, worden getroffen door de beperkte beschikbaarheid van die onlinezoekmachine;
- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een onlinezoekmachine is aangetast als gevolg van een vermoedelijk kwaadwillige handeling;
- d) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een onlinezoekmachine is aangetast, met gevolgen voor meer dan 5 % van de gebruikers van die onlinezoekmachine in de Unie, of voor meer dan 1 miljoen gebruikers van die onlinezoekmachine in de Unie, afhankelijk van welk aantal het kleinste is.

Artikel 13

Significante incidenten met betrekking tot aanbieders van platforms voor socialenetwerkdiensten

Met betrekking tot aanbieders van platforms voor socialenetwerkdiensten wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een platform voor socialenetwerkdiensten is volledig niet beschikbaar voor meer dan 5 % van de gebruikers van dat platform voor socialenetwerkdiensten in de Unie, of voor meer dan 1 miljoen gebruikers van dat platform voor socialenetwerkdiensten in de Unie, afhankelijk van welk aantal het kleinste is;
- b) meer dan 5 % van de gebruikers van een platform voor socialenetwerkdiensten in de Unie, of meer dan 1 miljoen gebruikers van een platform voor socialenetwerkdiensten in de Unie, afhankelijk van welk aantal het kleinste is, ondervinden gevolgen van de beperkte beschikbaarheid van dat platform voor socialenetwerkdiensten;
- c) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een platform voor socialenetwerkdiensten is aangetast als gevolg van een vermoedelijk kwaadwillige handeling;
- d) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een platform voor socialenetwerkdiensten is aangetast, met gevolgen voor meer dan 5 % van de gebruikers van dat platform voor socialenetwerkdiensten in de Unie, of voor meer dan 1 miljoen gebruikers van dat platform voor socialenetwerkdiensten in de Unie, afhankelijk van welk aantal het kleinste is.

*Artikel 14***Significante incidenten met betrekking tot verleners van vertrouwensdiensten**

Met betrekking tot verleners van vertrouwensdiensten wordt een incident als significant in de zin van artikel 3, lid 1, punt g), beschouwd indien aan een of meer van de volgende criteria is voldaan:

- a) een vertrouwensdienst is gedurende meer dan 20 minuten volledig niet beschikbaar;
- b) een vertrouwensdienst is gedurende meer dan een uur, berekend per kalenderweek, niet beschikbaar voor gebruikers of vertrouwende partijen;
- c) meer dan 1 % van de gebruikers of vertrouwende partijen in de Unie, of meer dan 200 000 gebruikers of vertrouwende partijen in de Unie, afhankelijk van welk aantal het kleinste is, worden door de beperkte beschikbaarheid van een vertrouwensdienst getroffen;
- d) de fysieke toegang tot een gebied waar netwerk- en informatiesystemen zich bevinden en waartoe de toegang is beperkt tot betrouwbaar personeel van de verlener van vertrouwensdiensten, of de bescherming van die fysieke toegang, is aangetast;
- e) de integriteit, de vertrouwelijkheid of de authenticiteit van opgeslagen, verzonden of verwerkte gegevens in verband met de verlening van een vertrouwensdienst is aangetast, met gevolgen voor meer dan 0,1 % van de gebruikers of vertrouwende partijen, of meer dan 100 gebruikers of vertrouwende partijen, afhankelijk van welk aantal het kleinste is, van de vertrouwensdienst in de Unie.

*Artikel 15***Intrekking**

Uitvoeringsverordening (EU) 2018/151 van de Commissie ⁽⁴⁾ wordt ingetrokken.

*Artikel 16***Inwerkingtreding en toepassing**

Deze richtlijn treedt in werking op de twintigste dag na die van de bekendmaking ervan in het *Publicatieblad van de Europese Unie*.

Deze verordening is verbindend in al haar onderdelen en is rechtstreeks toepasselijk in elke lidstaat.

Gedaan te Brussel, 17 oktober 2024.

Voor de Commissie
Ursula VON DER LEYEN
De voorzitter

⁽⁴⁾ Uitvoeringsverordening (EU) 2018/151 van de Commissie van 30 januari 2018 tot vaststelling van toepassingsbepalingen voor Richtlijn (EU) 2016/1148 van het Europees Parlement en de Raad wat betreft de nadere specificatie van de door digitaalendienstverleners in aanmerking te nemen elementen voor het beheer van de risico's in verband met de beveiliging van netwerk- en informatiesystemen en van de parameters om te bepalen of een incident aanzienlijke gevolgen heeft (PB L 26 van 31.1.2018, blz. 48, ELI: http://data.europa.eu/eli/reg_impl/2018/151/oj).

BIJLAGE

Technische en methodologische vereisten als bedoeld in artikel 2 van deze verordening

1. **Beleid inzake de beveiliging van netwerk- en informatiesystemen (artikel 21, lid 2, punt a), van Richtlijn (EU) 2022/2555)**
 - 1.1. *Beleid inzake de beveiliging van netwerk- en informatiesystemen*
 - 1.1.1. Voor de toepassing van artikel 21, lid 2, punt a), van Richtlijn (EU) 2022/2555 moet het beleid inzake de beveiliging van netwerk- en informatiesystemen:
 - a) de aanpak van de relevante entiteiten voor het beheer van de beveiliging van hun netwerk- en informatiesystemen vaststellen;
 - b) geschikt zijn voor en een aanvulling vormen op de bedrijfsstrategie en -doelstellingen van de relevante entiteiten;
 - c) doelstellingen op het gebied van netwerk- en informatiebeveiliging vaststellen;
 - d) een verbintenis omvatten om de beveiliging van netwerk- en informatiesystemen voortdurend te verbeteren;
 - e) een verbintenis omvatten om de passende middelen te bieden die nodig zijn voor de uitvoering ervan, met inbegrip van het nodige personeel, en de nodige financiële middelen, processen, instrumenten en technologieën;
 - f) worden meegedeeld aan en onderkend worden door relevante werknemers en belanghebbende externe partijen;
 - g) de taken en verantwoordelijkheden overeenkomstig punt 1.2 vaststellen;
 - h) de te bewaren documentatie en de bewaartermijn van de documentatie vermelden;
 - i) een overzicht geven van de thematische beleidsmaatregelen;
 - j) indicatoren en maatregelen vaststellen om de uitvoering ervan en de huidige status van het maturiteitsniveau van de beveiliging van de netwerk- en informatiesystemen van de relevante entiteiten te monitoren;
 - k) de datum van de formele goedkeuring door de bestuursorganen van de relevante entiteiten (de “bestuursorganen”) vermelden.
 - 1.1.2. Het beveiligingsbeleid inzake netwerk- en informatiesystemen moet ten minste jaarlijks door de bestuursorganen worden geëvalueerd en, waar passend, worden geactualiseerd en als zich significante incidenten of significante wijzigingen in de activiteiten of risico's voordoen. Het resultaat van de evaluaties moet worden gedocumenteerd.
 - 1.2. *Taken, verantwoordelijkheden en bevoegdheden*
 - 1.2.1. In het kader van hun beleid inzake de beveiliging van netwerk- en informatiesystemen als bedoeld in punt 1.1, stellen de relevante entiteiten de verantwoordelijkheden en bevoegdheden voor de beveiliging van netwerk- en informatiesystemen vast, wijzen zij deze taken toe overeenkomstig de behoeften van de relevante entiteiten en delen zij die mee aan de bestuursorganen.
 - 1.2.2. De relevante entiteiten verlangen van alle personeelsleden en derde partijen dat zij de beveiliging van netwerk- en informatiesystemen toepassen overeenkomstig het vastgestelde beleid inzake netwerk- en informatiebeveiliging, themaspecifieke beleidslijnen en de procedures van de relevante entiteiten.
 - 1.2.3. Ten minste één persoon brengt rechtstreeks verslag uit aan de bestuursorganen over aangelegenheden inzake de beveiliging van netwerk- en informatiesystemen.
 - 1.2.4. Afhankelijk van de omvang van de relevante entiteiten wordt de beveiliging van netwerk- en informatiesystemen gedekt door specifieke rollen of taken die naast de bestaande rollen worden uitgevoerd.

1.2.5. Conflicterende taken en conflicterende verantwoordelijkheidsgebieden worden, indien van toepassing, gescheiden.

1.2.6. Taken, verantwoordelijkheden en bevoegdheden worden op geplande tijdstippen en wanneer zich significante incidenten of significante veranderingen in de activiteiten of risico's voordoen, geëvalueerd en, waar passend, geactualiseerd door de bestuursorganen.

2. Risicobeheerbeleid (artikel 21, lid 2, punt a), van Richtlijn (EU) 2022/2555)

2.1. Kader voor risicobeheer

2.1.1. Voor de toepassing van artikel 21, lid 2, punt a), van Richtlijn (EU) 2022/2555 stellen de relevante entiteiten een passend kader voor risicobeheer vast en houden zij dit in stand om de risico's voor de beveiliging van netwerk- en informatiesystemen in kaart te brengen en aan te pakken. De relevante entiteiten voeren risicobeoordelingen uit en documenteren die en op basis van de resultaten stellen zij een risicobehandelingsplan vast dat zij uitvoeren en monitoren. De resultaten van de risicobeoordeling en de restrisico's worden aanvaard door de bestuursorganen of, indien van toepassing, door personen die verantwoordelijk en bevoegd zijn om risico's te beheren, mits de relevante entiteiten zorgen voor adequate rapportage aan de bestuursorganen.

2.1.2. Voor de toepassing van punt 2.1.1 stellen de relevante entiteiten procedures vast voor de bepaling, de analyse, de beoordeling en de behandeling van risico's ("proces voor het beheer van cyberbeveiligingsrisico's"). Het proces voor het beheer van cyberbeveiligingsrisico's maakt, indien van toepassing, integraal deel uit van het algehele risicobeheerproces van de relevante entiteiten. Als onderdeel van het proces voor het beheer van cyberbeveiligingsrisico's zullen de relevante entiteiten:

- a) een risicobeheermethode volgen;
- b) het risicotolerantieniveau vaststellen overeenkomstig de risicobereidheid van de relevante entiteiten;
- c) relevante risicocriteria vaststellen en handhaven;
- d) op basis van een benadering die alle gevaren omvat, de risico's voor de beveiliging van netwerk- en informatiesystemen, met name met betrekking tot derden, en risico's die kunnen leiden tot verstoringen van de beschikbaarheid, de integriteit, de authenticiteit en de vertrouwelijkheid van de netwerk- en informatiesystemen, met inbegrip van de identificatie van zwakke punten, in kaart brengen en documenteren;
- e) de risico's voor de beveiliging van netwerk- en informatiesystemen analyseren, met inbegrip van dreigingen, de waarschijnlijkheid, de impact en het risiconiveau, rekening houdend met inlichtingen over cyberdreigingen en kwetsbaarheden;
- f) de vastgestelde risico's evalueren op basis van de risicocriteria;
- g) passende risicobehandelingsopties en -maatregelen in kaart brengen en prioriteren;
- h) permanent toezicht houden op de uitvoering van de risicobehandelingsmaatregelen;
- i) vaststellen wie verantwoordelijk is voor de uitvoering van de risicobehandelingsmaatregelen en wanneer deze moeten worden uitgevoerd;
- j) de gekozen risicobehandelingsmaatregelen in een risicobehandelingsplan documenteren en de redenen voor de aanvaarding van restrisico's op begrijpelijke wijze rechtvaardigen.

2.1.3. Bij het vaststellen en prioriteren van passende risicobehandelingsopties en -maatregelen houden de relevante entiteiten rekening met de resultaten van de risicobeoordeling, de resultaten van de procedure om de doeltreffendheid van risicobeheersmaatregelen op het gebied van cyberbeveiliging te beoordelen, de uitvoeringskosten in verhouding tot het verwachte voordeel, de in punt 12.1 bedoelde classificatie van activa en de in punt 4.1.3 bedoelde bedrijfsimpactanalyse.

2.1.4. De relevante entiteiten evalueren en actualiseren, waar passend, de resultaten van de risicobeoordeling en het risicobehandelingsplan met geplande tussenpozen en ten minste eenmaal per jaar, en wanneer zich significante veranderingen in de activiteiten of risico's of significante incidenten voordoen.

2.2. Toezicht op de naleving

- 2.2.1. De relevante entiteiten evalueren regelmatig de naleving van hun beleid inzake netwerk- en informatiebeveiliging, thematische beleidslijnen, regels en normen. De bestuursorganen worden door middel van regelmatige rapportage over de nalevingsbeoordelingen op de hoogte gebracht van de status van de netwerk- en informatiebeveiliging.
- 2.2.2. De relevante entiteiten zetten een doeltreffend systeem voor nalevingsrapportage op dat is afgestemd op hun structuren, operationele omgevingen en dreigingslandschappen. Met dit systeem voor nalevingsrapportage kunnen de bestuursorganen een geïnformeerd beeld krijgen van de huidige stand van zaken met betrekking tot het risicobeheer van de relevante entiteiten.
- 2.2.3. De relevante entiteiten voeren de nalevingsmonitoring uit met geplande tussenpozen en wanneer zich significante incidenten of significante wijzigingen in de activiteiten of risico's voordoen.

2.3. Onafhankelijke evaluatie van de informatie- en netwerkbeveiliging

- 2.3.1. De relevante entiteiten evalueren op onafhankelijke wijze hun aanpak van het beheer van de beveiliging van netwerk- en informatiesystemen en de uitvoering daarvan, met inbegrip van mensen, processen en technologieën.
- 2.3.2. De relevante entiteiten ontwikkelen en handhaven processen voor het uitvoeren van onafhankelijke evaluaties, die worden uitgevoerd door personen met passende auditcompetentie. Indien de onafhankelijke toetsing wordt uitgevoerd door personeelsleden van de relevante entiteit, mogen de personen die de beoordelingen uitvoeren niet onder het gezag staan van het personeel van het te beoordelen gebied. Indien door de omvang van de relevante entiteiten een dergelijke scheiding van gezag niet mogelijk is, nemen de relevante entiteiten alternatieve maatregelen om de onpartijdigheid van de toetsingen te waarborgen.
- 2.3.3. De resultaten van de onafhankelijke toetsingen, met inbegrip van de resultaten van het toezicht op de naleving overeenkomstig punt 2.2 en de monitoring en de meting overeenkomstig punt 7, worden aan de bestuursorganen gerapporteerd. Er worden corrigerende maatregelen genomen of restrisico's aanvaard overeenkomstig de risicoaanvaardingscriteria van de relevante entiteiten.
- 2.3.4. De onafhankelijke evaluaties vinden plaats met geplande tussenpozen en wanneer zich significante incidenten of significante veranderingen in de activiteiten of risico's voordoen.

3. Incidentenbehandeling (artikel 21, lid 2, punt b), van Richtlijn (EU) 2022/2555)

3.1. Beleid inzake incidentenbehandeling

- 3.1.1. Voor de toepassing van artikel 21, lid 2, punt b), van Richtlijn (EU) 2022/2555 stellen de relevante entiteiten een beleid inzake incidentenbehandeling vast, waarin de rollen, verantwoordelijkheden en procedures voor het tijdig opsporen, analyseren, beheersen of reageren op, en het herstellen, documenteren en rapporteren van incidenten worden vastgelegd, en voeren zij dit beleid uit.
- 3.1.2. Het in punt 3.1.1 bedoelde beleid is in overeenstemming met het in punt 4.1 bedoelde bedrijfscontinuïteits- en noodvoorzieningenplan. Het beleid omvat:
 - a) een classificatiesysteem voor incidenten dat in overeenstemming is met de volgens punt 3.4.1 uitgevoerde beoordeling en classificatie van gebeurtenissen;
 - b) doeltreffende communicatieplannen, onder meer voor escalatie en rapportage;
 - c) een toewijzing van taken aan bekwame werknemers om incidenten op te sporen en op passende wijze te reageren;
 - d) documenten die moeten worden gebruikt bij de opsporing van en de incidentrespons, zoals handleidingen voor incidentrespons, escalatieschema's, contactlijsten en modellen.
- 3.1.3. De in het beleid vastgestelde taken, verantwoordelijkheden en procedures worden getest en geëvalueerd en, waar passend, geactualiseerd met geplande tussenpozen en na significante incidenten of significante wijzigingen in de activiteiten of risico's.

3.2. Monitoring en logging

- 3.2.1. De relevante entiteiten stellen procedures vast en gebruiken instrumenten om activiteiten in hun netwerk- en informatiesystemen te monitoren en te registreren om gebeurtenissen op te sporen die als incidenten kunnen worden beschouwd, en reageren dienovereenkomstig om de gevolgen te beperken.
- 3.2.2. Voor zover haalbaar wordt de monitoring geautomatiseerd en hetzij continu, hetzij met periodieke tussenpozen uitgevoerd, afhankelijk van de bedrijfsmogelijkheden. De relevante entiteiten voeren hun monitoringactiviteiten uit op een wijze die foutpositieve en foutnegatieve uitslagen tot een minimum beperkt.
- 3.2.3. Op basis van de in punt 3.2.1 bedoelde procedures houden de relevante entiteiten logbestanden bij, die zij documenteren en evalueren. De relevante entiteiten stellen op basis van de resultaten van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling een lijst op van de activa die in logbestanden moeten worden bijgehouden. Waar passend bevatten de logbestanden:
- a) relevant uitgaand en inkomend netwerkverkeer;
 - b) de aanmaak, wijziging of verwijdering van gebruikers van de netwerk- en informatiesystemen van de relevante entiteiten en de uitbreiding van de machtigingen;
 - c) toegang tot systemen en toepassingen;
 - d) gebeurtenissen in verband met authenticatie;
 - e) alle bevoorrechte toegang tot systemen en toepassingen, en activiteiten van beheeraccounts;
 - f) toegang tot of wijzigingen van kritieke configuratie- en back-upbestanden;
 - g) logbestanden van gebeurtenissen en logbestanden van beveiligingsinstrumenten, zoals antivirus, inbraakdetectiesystemen of firewalls;
 - h) het gebruik van systeembronnen en de prestaties daarvan;
 - i) fysieke toegang tot faciliteiten;
 - j) toegang tot en gebruik van netwerkuitrusting en -apparatuur;
 - k) het activeren, stoppen en pauzeren van de verschillende logboeken;
 - l) omgevingsgebeurtenissen.
- 3.2.4. De logbestanden worden regelmatig nagekeken op ongebruikelijke of ongewenste trends. Waar passend stellen de relevante entiteiten passende waarden voor alarmdrempels vast. Indien de vastgestelde alarmdrempels worden overschreden, wordt waar passend automatisch een alarm geactiveerd. De relevante entiteiten zorgen ervoor dat in geval van een alarm tijdig een gekwalificeerd en passend antwoord wordt gegeven.
- 3.2.5. De relevante entiteiten houden gedurende een vooraf bepaalde periode logbestanden bij en beschermen die tegen ongeoorloofde toegang of wijzigingen.
- 3.2.6. Voor zover haalbaar zorgen de relevante entiteiten ervoor dat alle systemen gesynchroniseerde tijdsbronnen hebben om logbestanden tussen systemen te kunnen correleren voor de beoordeling van gebeurtenissen. De relevante entiteiten stellen een lijst op van alle activa die in logbestanden worden bijgehouden en zorgen ervoor dat monitoring- en loggingsystemen redundant zijn. De beschikbaarheid van de monitoring- en loggingsystemen wordt gemonitord onafhankelijk van de systemen die zij monitoren.
- 3.2.7. De procedures en de lijst van activa die worden geregistreerd, worden regelmatig en na significante incidenten geëvalueerd en, waar passend, geactualiseerd.

3.3. Melding van gebeurtenissen

- 3.3.1. De relevante entiteiten zetten een eenvoudig mechanisme op dat hun werknemers, leveranciers en klanten in staat stelt verdachte gebeurtenissen te melden.

3.3.2. Waar passend delen de relevante entiteiten het mechanisme voor de melding van gebeurtenissen mee aan hun leveranciers en klanten en bieden zij hun werknemers regelmatig opleiding inzake het gebruik van het mechanisme.

3.4. *Beoordeling en classificatie van gebeurtenissen*

3.4.1. De relevante entiteiten beoordelen verdachte gebeurtenissen om te bepalen of het om incidenten gaat en, zo ja, om de aard en de ernst ervan te bepalen.

3.4.2. Voor de toepassing van punt 3.4.1 handelen de relevante entiteiten als volgt:

- a) zij voeren de beoordeling uit op basis van vooraf vastgestelde criteria, en op basis van een selectie om de prioritering van het indammen en elimineren van incidenten te bepalen;
- b) zij beoordelen op kwartaalbasis het vóórkomen van terugkerende incidenten als bedoeld in artikel 4;
- c) zij kijken de passende logbestanden na met het oog op de beoordeling en de classificatie van gebeurtenissen;
- d) zij voeren een proces voor logcorrelatie en loganalyse in, en
- e) zij beoordelen en classificeren gebeurtenissen opnieuw wanneer nieuwe informatie beschikbaar komt of na analyse van eerder beschikbare informatie.

3.5. *Incidentrespons*

3.5.1. De relevante entiteiten reageren tijdig en volgens gedocumenteerde procedures op incidenten.

3.5.2. De procedures voor incidentrespons omvatten de volgende fasen:

- a) indamming van incidenten, om te voorkomen dat de gevolgen van het incident zich verspreiden;
- b) eliminatie, om te voorkomen dat het incident voortduurt of opnieuw voorvalt;
- c) herstel van het incident, indien nodig.

3.5.3. De relevante entiteiten stellen communicatieplannen en -procedures vast:

- a) met de Computer Security Incident Response Teams (CSIRT's) of, indien van toepassing, de bevoegde autoriteiten, met betrekking tot de melding van incidenten;
- b) voor communicatie tussen personeelsleden van de relevante entiteit en voor communicatie met relevante belanghebbenden buiten de relevante entiteit.

3.5.4. De relevante entiteiten registreren de activiteiten van de incidentrespons overeenkomstig de in punt 3.2.1 bedoelde procedures en leggen bewijsmateriaal vast.

3.5.5. De relevante entiteiten testen met geplande tussenpozen hun procedures voor incidentrespons.

3.6. *Evaluaties na incidenten*

3.6.1. Na het herstel van incidenten verrichten de relevante entiteiten, waar passend, post-incident-evaluaties. Bij de evaluaties na het incident wordt, waar mogelijk, de onderliggende oorzaak van het incident vastgesteld en worden ervaringen gedocumenteerd om het vóórkomen en de gevolgen van toekomstige incidenten te beperken.

3.6.2. De relevante entiteiten zorgen ervoor dat post-incident-evaluaties bijdragen tot een betere aanpak van netwerk- en informatiebeveiliging, betere risicobehandelingsmaatregelen en betere procedures voor de behandeling en opsporing van incidenten en incidentrespons.

3.6.3. De relevante entiteiten evalueren met geplande tussenpozen of deze post-incident-evaluaties zijn uitgevoerd.

4. **Bedrijfscontinuïteit en crisisbeheer (artikel 21, lid 2, punt c), van Richtlijn (EU) 2022/2555)**

4.1. *Bedrijfscontinuïteits- en noodvoorzieningenplan*

4.1.1. Voor de toepassing van artikel 21, lid 2, punt c), van Richtlijn (EU) 2022/2555 stellen de relevante entiteiten een bedrijfscontinuïteits- en noodvoorzieningenplan vast dat in geval van incidenten moet worden toegepast.

4.1.2. De activiteiten van de relevante entiteiten worden hersteld overeenkomstig het bedrijfscontinuïteits- en noodvoorzieningenplan. Het plan wordt gebaseerd op de resultaten van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling en omvat, waar passend, het volgende:

- a) doel, reikwijdte en publiek;
- b) taken en verantwoordelijkheden;
- c) belangrijkste contacten en (interne en externe) communicatiekanalen;
- d) voorwaarden voor activering en deactivering van het plan;
- e) opdracht tot hervatting van de activiteiten;
- f) herstelplannen voor specifieke activiteiten, met inbegrip van hersteldoelstellingen;
- g) de vereiste middelen, met inbegrip van back-ups en redundancies;
- h) herstel en hervatting van activiteiten na afloop van tijdelijke maatregelen.

4.1.3. De relevante entiteiten voeren een bedrijfsimpactanalyse uit om de mogelijke gevolgen van ernstige verstoringen van hun bedrijfsactiviteiten te beoordelen en stellen, op basis van de resultaten van de bedrijfsimpactanalyse, continuïteitsvereisten voor de netwerk- en informatiesystemen vast.

4.1.4. Het bedrijfscontinuïteitsplan en het noodvoorzieningenplan worden getest, geëvalueerd en, waar passend, bijgewerkt, met geplande tussenpozen of na significante incidenten of significante wijzigingen in de activiteiten of risico's. De relevante entiteiten zorgen ervoor dat in de plannen rekening wordt gehouden met de lessen die uit dergelijke tests zijn getrokken.

4.2. *Back-up- en redundantiebeheer*

4.2.1. De relevante entiteiten houden reservekopieën (back-ups) van gegevens bij en stellen voldoende middelen ter beschikking, waaronder faciliteiten, netwerk- en informatiesystemen en personeel, om een passend niveau van redundantie te waarborgen.

4.2.2. Op basis van de resultaten van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling en het bedrijfscontinuïteitsplan stellen de relevante entiteiten back-upplannen vast die het volgende omvatten:

- a) hersteltijden;
- b) garantie dat back-ups volledig en nauwkeurig zijn, met inbegrip van configuratiegegevens en gegevens die zijn opgeslagen in cloudcomputingdiensten;
- c) opslag van back-ups (online of offline) op een veilige locatie of locaties die zich niet in hetzelfde netwerk bevinden als het systeem, en die op voldoende afstand liggen om geen schade te ondervinden van een calamiteit op de hoofdlocatie;
- d) passende fysieke en logische toegangscontroles tot back-ups, in overeenstemming met het classificatieniveau van de activa;
- e) herstel van gegevens uit back-ups;
- f) bewaartermijnen op basis van zakelijke en wettelijke vereisten.

4.2.3. De relevante entiteiten voeren regelmatig integriteitscontroles uit op de back-ups.

4.2.4. Op basis van de resultaten van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling en het bedrijfscontinuïteitsplan zorgen de relevante entiteiten ervoor dat voldoende middelen beschikbaar zijn door ten minste gedeeltelijke redundantie van:

- a) netwerk- en informatiesystemen;
- b) activa, met inbegrip van faciliteiten, uitrusting en benodigdheden;
- c) personeel met de nodige verantwoordelijkheid, bevoegdheid en bekwaamheid;
- d) passende communicatiekanalen.

4.2.5. Waar passend zorgen de relevante entiteiten ervoor dat de monitoring en de aanpassing van middelen, met inbegrip van faciliteiten, systemen en personeel, naar behoren worden ondersteund door informatie over de vereisten inzake back-ups en redundantie.

4.2.6. De relevante entiteiten testen regelmatig het terugzetten van back-ups en de redundantie om ervoor te zorgen dat zij in herstelomstandigheden kunnen worden ingezet en dat de kopieën, processen en kennis beschikbaar zijn om een doeltreffend herstel uit te voeren. De relevante entiteiten documenteren de resultaten van de tests en nemen zo nodig corrigerende maatregelen.

4.3. Crisisbeheersing

4.3.1. De relevante entiteiten voeren een proces voor crisisbeheersing in.

4.3.2. De relevante entiteiten zorgen ervoor dat het crisisbeheersingsproces ten minste betrekking heeft op de volgende elementen:

- a) taken en verantwoordelijkheden voor het personeel en, waar passend, leveranciers en dienstverleners, met vermelding van de taakverdeling in crisissituaties, met inbegrip van specifiek te volgen stappen;
- b) passende communicatiemiddelen tussen de relevante entiteiten en de relevante bevoegde autoriteiten;
- c) toepassing van passende maatregelen om de veiligheid van de netwerk- en informatiesystemen in crisissituaties te waarborgen.

Voor de toepassing van punt b) omvat de informatiestroom tussen de relevante entiteiten en de relevante bevoegde autoriteiten zowel verplichte mededelingen, zoals incidentverslagen en bijbehorende tijdschema's, als niet-verplichte mededelingen.

4.3.3. De relevante entiteiten voeren een proces in voor het beheer en het gebruik van de CSIRT's of, indien van toepassing, van de bevoegde autoriteiten ontvangen informatie over incidenten, kwetsbaarheden, dreigingen of mogelijke risicobeperkende maatregelen.

4.3.4. De relevante entiteiten testen, evalueren en, waar passend, actualiseren het crisisbeheersingsplan op gezette tijden of naar aanleiding van significante incidenten of significante wijzigingen in operaties of risico's.

5. Beveiliging van de toeleveringsketen (artikel 21, lid 2, punt d), van Richtlijn (EU) 2022/2555)

5.1. Beleid inzake de beveiliging van de toeleveringsketen

5.1.1. Voor de toepassing van artikel 21, lid 2, punt d), van Richtlijn (EU) 2022/2555 zorgen de relevante entiteiten voor de vaststelling, de uitvoering en de toepassing van een beleid inzake de beveiliging van de toeleveringsketen dat de betrekkingen met hun directe leveranciers en dienstverleners regelt, teneinde de vastgestelde risico's voor de beveiliging van netwerk- en informatiesystemen te beperken. In het beleid inzake de beveiliging van de toeleveringsketen bepalen de relevante entiteiten hun rol in de toeleveringsketen en delen zij deze mee aan hun directe leveranciers en dienstverleners.

5.1.2. Als onderdeel van het in punt 5.1.1 bedoelde beleid inzake de beveiliging van de toeleveringsketen stellen de relevante entiteiten criteria vast voor het selecteren en contracteren van leveranciers en dienstverleners. Die criteria omvatten:

- a) de cyberbeveiligingspraktijken van de leveranciers en dienstverleners, met inbegrip van hun beveiligde ontwikkelingsprocedures;
- b) het vermogen van de leveranciers en dienstverleners om te voldoen aan de door de relevante entiteiten vastgestelde cyberbeveiligingsspecificaties;
- c) de algemene kwaliteit en veerkracht van ICT-producten en -diensten en de daarin vervatte maatregelen voor het beheer van cyberbeveiligingsrisico's, met inbegrip van de risico's en het classificatieniveau van de ICT-producten en -diensten;
- d) het vermogen van de relevante entiteiten om de leveringsbronnen te diversifiëren en de afhankelijkheid van verkopers te beperken, indien van toepassing.

5.1.3. Bij het vaststellen van hun beleid inzake de beveiliging van de toeleveringsketen houden de relevante entiteiten, indien van toepassing, rekening met de resultaten van de gecoördineerde beveiligingsrisicobeoordelingen van kritieke toeleveringsketens die zijn uitgevoerd overeenkomstig artikel 22, lid 1, van Richtlijn (EU) 2022/2555.

5.1.4. Op basis van het beleid inzake de beveiliging van de toeleveringsketen en rekening houdend met de resultaten van de overeenkomstig punt 2.1 van deze bijlage uitgevoerde risicobeoordeling, zorgen de relevante entiteiten ervoor dat hun contracten met de leveranciers en dienstverleners, waar passend door middel van overeenkomsten inzake dienstverleningsniveau, het volgende specificeren:

- a) cyberbeveiligingsvereisten voor de leveranciers of dienstverleners, met inbegrip van de in punt 6.1 vastgestelde vereisten met betrekking tot de beveiliging bij de verwerving van ICT-diensten of ICT-producten;
- b) vereisten inzake risicobewustzijn, vaardigheden en opleiding en, waar passend, certificaten die van de werknemers van de leveranciers of dienstverleners worden verlangd;
- c) vereisten inzake de verificatie van de achtergrond van de werknemers van leveranciers en dienstverleners;
- d) een verplichting voor leveranciers en dienstverleners om de relevante entiteiten onverwijld in kennis te stellen van incidenten die een risico vormen voor de beveiliging van de netwerk- en informatiesystemen van die entiteiten;
- e) het recht op controle of het recht om auditverslagen te ontvangen;
- f) een verplichting voor leveranciers en dienstverleners om kwetsbaarheden aan te pakken die een risico vormen voor de beveiliging van de netwerk- en informatiesystemen van de relevante entiteiten;
- g) vereisten inzake uitbesteding en, indien de relevante entiteiten onderaanneming toestaan, cyberbeveiligingsvereisten voor onderaannemers in overeenstemming met de in punt a) bedoelde cyberbeveiligingsvereisten;
- h) verplichtingen voor de leveranciers en dienstverleners bij beëindiging van het contract, zoals het verzamelen en verwijderen van de informatie die de leveranciers en dienstverleners bij de uitoefening van hun taken hebben verkregen.

5.1.5. De relevante entiteiten houden rekening met de in de punten 5.1.2 en 5.1.3 bedoelde elementen als onderdeel van het selectieproces van nieuwe leveranciers en dienstverleners, alsook als onderdeel van het in punt 6.1 bedoelde aanbestedingsproces.

5.1.6. De relevante entiteiten evalueren het beleid inzake de beveiliging van de toeleveringsketen en monitoren, evalueren en, indien nodig, handelen in geval van veranderingen in de cyberbeveiligingspraktijken van leveranciers en dienstverleners, met geplande tussenpozen en wanneer zich significante wijzigingen voordoen in de activiteiten of risico's of significante incidenten in verband met de verlening van ICT-diensten of incidenten met gevolgen voor de beveiliging van ICT-producten van leveranciers en dienstverleners.

5.1.7. Voor de toepassing van punt 5.1.6 zullen de relevante entiteiten:

- a) indien van toepassing, regelmatig toezicht houden op de verslagen over de uitvoering van de overeenkomsten inzake dienstverleningsniveau;
- b) incidenten met betrekking tot ICT-producten en -diensten van leveranciers en dienstverleners evalueren;
- c) de noodzaak van ongeplande evaluaties beoordelen en de bevindingen op begrijpelijke wijze documenteren;
- d) de risico's van veranderingen in verband met ICT-producten en -diensten van leveranciers en dienstverleners analyseren en, waar passend, tijdig risicobeperkende maatregelen nemen.

5.2. *Register van leveranciers en dienstverleners*

De relevante entiteiten houden een register bij van hun directe leveranciers en dienstverleners, met inbegrip van:

- a) contactpunten per direct leverancier en dienstverlener;
- b) een lijst van ICT-producten, -diensten en -processen die door de direct leverancier of dienstverlener aan de relevante entiteiten worden geleverd.

6. **Beveiliging bij het verwerven, ontwikkelen en onderhouden van netwerk- en informatiesystemen (artikel 21, lid 2, punt e), van Richtlijn (EU) 2022/2555)**

6.1. *Beveiliging bij het verwerven van ICT-diensten of ICT-producten*

6.1.1. Voor de toepassing van artikel 21, lid 2, punt e), van Richtlijn (EU) 2022/2555 bepalen en implementeren de relevante entiteiten, op basis van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling, processen voor het beheer van risico's die voortvloeien uit het verwerven van ICT-diensten of ICT-producten van leveranciers of dienstverleners voor componenten die van cruciaal belang zijn voor de beveiliging van netwerk- en informatiesystemen van de relevante entiteiten, en dat gedurende hun hele levenscyclus.

6.1.2. Voor de toepassing van punt 6.1.1 omvatten de in punt 6.1.1 bedoelde processen:

- a) beveiligingsvoorschriften die van toepassing zijn op de aan te schaffen ICT-diensten of -producten;
- b) vereisten inzake beveiligingsupdates gedurende de gehele levensduur van de ICT-diensten of ICT-producten, of vervanging na het einde van de ondersteuningsperiode;
- c) informatie over de hardware- en softwarecomponenten die in de ICT-diensten of ICT-producten worden gebruikt;
- d) informatie over de uitgevoerde cyberbeveiligingsfuncties van de ICT-diensten of ICT-producten en de configuratie die nodig is voor de veilige werking ervan;
- e) de garantie dat de ICT-diensten of ICT-producten voldoen aan de beveiligingsvereisten overeenkomstig punt a);
- f) methoden om te valideren dat de geleverde ICT-diensten of ICT-producten aan de vermelde beveiligingseisen voldoen, alsmede documentatie van de resultaten van de validering.

6.1.3. De relevante entiteiten evalueren en, waar passend, actualiseren de processen met geplande tussenpozen en wanneer zich significante incidenten voordoen.

6.2. *Beveiligde ontwikkelingscyclus*

6.2.1. Alvorens een netwerk- en informatiesysteem, met inbegrip van software, te ontwikkelen, stellen de relevante entiteiten regels vast voor de beveiligde ontwikkeling van netwerk- en informatiesystemen en passen zij die toe bij de ontwikkeling van interne netwerk- en informatiesystemen of bij de uitbesteding van de ontwikkeling van netwerk- en informatiesystemen. De regels hebben betrekking op alle ontwikkelingsfasen, met inbegrip van specificatie, ontwerp, ontwikkeling, implementatie en tests.

6.2.2. Voor de toepassing van punt 6.2.1 zullen de relevante entiteiten:

- a) een analyse uitvoeren van de beveiligingsvoorschriften in de specificatie- en ontwerpfase van elk ontwikkelings- of overnameproject dat door of namens die entiteiten wordt uitgevoerd;
- b) beginselen voor de engineering van veilige systemen en beginselen voor veilige codering toepassen op alle activiteiten voor de ontwikkeling van informatiesystemen, zoals het bevorderen van cyberbeveiliging-by-design of zero trust-architectuur;
- c) beveiligingsvoorschriften vaststellen met betrekking tot ontwikkelingsomgevingen;
- d) beveiligingstestprocessen vaststellen en toepassen in de ontwikkelingscyclus;
- e) gegevens over beveiligingstests op passende wijze selecteren, beschermen en beheren;
- f) testgegevens saneren en anonimiseren overeenkomstig de volgens punt 2.1 uitgevoerde risicobeoordeling.

6.2.3. Voor de uitbestede ontwikkeling van netwerk- en informatiesystemen passen de relevante entiteiten tevens de in de punten 5 en 6.1 bedoelde beleidslijnen en procedures toe.

6.2.4. Met geplande tussenpozen evalueren en, indien nodig, actualiseren de relevante entiteiten hun voorschriften voor een beveiligde ontwikkeling.

6.3. Configuratiebeheer

6.3.1. De relevante entiteiten nemen passende maatregelen om configuraties vast te stellen, te documenteren, uit te voeren en te monitoren, met inbegrip van beveiligingsconfiguraties van hardware, software, diensten en netwerken.

6.3.2. Voor de toepassing van punt 6.3.1 zullen de relevante entiteiten:

- a) de beveiliging in configuraties voor hun hardware, software, diensten en netwerken vaststellen en waarborgen;
- b) procedures en instrumenten vaststellen en toepassen om de vastgestelde veilige configuraties te handhaven voor hardware, software, diensten en netwerken, voor nieuw geïnstalleerde systemen en voor systemen in bedrijf, gedurende hun levensduur.

6.3.3. De relevante entiteiten evalueren en, waar passend, actualiseren configuraties met geplande tussenpozen of wanneer zich significante incidenten of significante wijzigingen in de activiteiten of risico's voordoen.

6.4. Veranderingsbeheer, reparatie en onderhoud

6.4.1. De relevante entiteiten passen procedures voor veranderingsbeheer toe om wijzigingen van netwerk- en informatiesystemen te controleren. Indien van toepassing moeten de procedures in overeenstemming zijn met het algemene beleid van de relevante entiteiten inzake veranderingsbeheer.

6.4.2. De in punt 6.4.1 bedoelde procedures worden toegepast voor releases, wijzigingen en noodwijzigingen van in bedrijf zijnde software en hardware, en wijzigingen in de configuratie. De procedures zorgen ervoor dat die wijzigingen worden gedocumenteerd en, op basis van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling, worden getest en beoordeeld in het licht van de mogelijke gevolgen voordat zij worden uitgevoerd.

6.4.3. Indien de reguliere procedures voor veranderingsbeheer niet konden worden gevolgd als gevolg van een noodsituatie, documenteren de relevante entiteiten het resultaat van de wijziging en de uitleg waarom de procedures niet konden worden gevolgd.

6.4.4. De relevante entiteiten evalueren en, waar passend, actualiseren de procedures met geplande tussenpozen en wanneer significante incidenten of significante wijzigingen in activiteiten of risico's plaatsvinden.

6.5. Beveiligingstests

6.5.1. De relevante entiteiten dragen zorg voor het vaststellen, uitvoeren en toepassen van een beleid en procedures voor beveiligingstests.

6.5.2. De relevante entiteiten:

- a) stellen, op basis van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling, de noodzaak, de reikwijdte, de frequentie en het type van de beveiligingstests vast;
- b) voeren beveiligingstests uit volgens een gedocumenteerde testmethode, die betrekking heeft op de componenten die in een risicoanalyse als relevant voor een veilige werking zijn aangemerkt;
- c) documenteren het type, de reikwijdte, het tijdstip en de resultaten van de tests, met inbegrip van de beoordeling van het kritieke karakter en de risicobeperkende maatregelen voor elke bevinding;
- d) passen risicobeperkende maatregelen toe in geval van kritieke bevindingen.

6.5.3. De relevante entiteiten evalueren en, waar passend, actualiseren hun beveiligingstestbeleid met geplande tussenpozen.

6.6. Beveiligingspatchbeheer

6.6.1. De relevante entiteiten specificeren en passen procedures toe die in overeenstemming zijn met de in punt 6.4.1 bedoelde procedures voor veranderingsbeheer en met de procedures voor kwetsbaarheidsbeheer, risicobeheer en andere relevante beheerprocedures, om ervoor te zorgen dat:

- a) beveiligingspatches worden toegepast binnen een redelijke termijn nadat zij beschikbaar zijn;
- b) beveiligingspatches worden getest voordat zij in productiesystemen worden toegepast;
- c) beveiligingspatches afkomstig zijn van betrouwbare bronnen en op integriteit worden gecontroleerd;
- d) er aanvullende maatregelen worden genomen en restrisico's worden aanvaard in gevallen waarin een patch niet beschikbaar is of niet wordt toegepast overeenkomstig punt 6.6.2.

6.6.2. In afwijking van punt 6.6.1, punt a), kunnen de relevante entiteiten ervoor kiezen geen beveiligingspatches toe te passen wanneer de nadelen van de toepassing van de beveiligingspatches zwaarder wegen dan de voordelen op het gebied van cyberbeveiliging. De relevante entiteiten documenteren en motiveren naar behoren de redenen voor een dergelijk besluit.

6.7. Netwerkbeveiliging

6.7.1. De relevante entiteiten nemen passende maatregelen om hun netwerk- en informatiesystemen tegen cyberdreigingen te beschermen.

6.7.2. Voor de toepassing van punt 6.7.1 zullen de relevante entiteiten:

- a) de architectuur van het netwerk op begrijpelijke en actuele wijze documenteren;
- b) controles vaststellen en toepassen om de interne netwerkdomeinen van de relevante entiteiten te beschermen tegen ongeoorloofde toegang;
- c) controles configureren om toegang en netwerkcommunicatie te voorkomen die niet vereist zijn voor de werking van de relevante entiteiten;
- d) controles bepalen en toepassen voor toegang op afstand tot netwerk- en informatiesystemen, met inbegrip van dienstenaanbieders;
- e) geen systemen voor het beheer van de uitvoering van het beveiligingsbeleid, voor andere doeleinden gebruiken;
- f) niet-noodzakelijke aansluitingen en diensten uitdrukkelijk verbieden of deactiveren;
- g) waar passend uitsluitend toegang verlenen tot de netwerk- en informatiesystemen van de relevante entiteiten door middel van door die entiteiten gemachtigde apparatuur;
- h) aansluitingen van dienstverleners alleen toestaan na een autorisatieverzoek en voor een bepaalde periode, zoals de duur van een onderhoudsactiviteit;

- i) zorgen voor communicatie tussen verschillende systemen uitsluitend via betrouwbare kanalen die geïsoleerd zijn door middel van logische, cryptografische of fysieke scheiding van andere communicatiekanalen, en zorgen voor een gegarandeerde bepaling van hun eindpunten en bescherming van de kanaalgegevens tegen wijziging of openbaarmaking;
- j) een uitvoeringsplan vaststellen voor de volledige overgang naar communicatieprotocollen van de recentste generatie netwerklaag op een veilige, passende en geleidelijke manier en maatregelen vaststellen om die overgang te versnellen;
- k) een uitvoeringsplan vaststellen voor de invoering van internationaal overeengekomen en interoperabele moderne normen voor e-mailcommunicatie om e-mailcommunicatie te beveiligen om kwetsbaarheden in verband met e-mailgerelateerde dreigingen te beperken, en maatregelen vast te stellen om die uitrol te versnellen;
- l) beste praktijken toepassen voor de beveiliging van de DNS en voor de routingbeveiliging en routinghygiëne op het internet van het verkeer dat afkomstig is van en bestemd is voor het netwerk.

6.7.3. De relevante entiteiten evalueren en, waar passend, actualiseren deze maatregelen met geplande tussenpozen en wanneer zich significante incidenten of significante wijzigingen in de activiteiten of risico's voordoen.

6.8. *Netwerksegmentatie*

6.8.1. De relevante entiteiten segmenteren systemen in netwerken of zones overeenkomstig de resultaten van de in punt 2.1 bedoelde risicobeoordeling. Zij segmenteren hun systemen en netwerken van systemen en netwerken van derden.

6.8.2. Daartoe zullen de relevante entiteiten:

- a) rekening houden met de functionele, logische en fysieke relatie, met inbegrip van de locatie, tussen betrouwbare systemen en diensten;
- b) toegang verlenen tot een netwerk of zone op basis van een beoordeling van de beveiligingsvoorschriften;
- c) systemen behouden die van cruciaal belang zijn voor de werking van de relevante entiteiten of voor de veiligheid in beveiligde zones;
- d) een gedemilitariseerde zone in hun communicatienetwerken uitrollen om te waarborgen dat communicatie die afkomstig is van of bestemd is voor hun netwerken, beveiligd is;
- e) de toegang tot en de communicatie tussen en binnen zones beperken tot die welke nodig zijn voor de werking van de relevante entiteiten of voor de veiligheid;
- f) het specifieke netwerk voor het beheer van netwerk- en informatiesystemen scheiden van het operationele netwerk van de relevante entiteiten;
- g) de kanalen voor netwerkbeheer scheiden van ander netwerkverkeer;
- h) de productiesystemen voor de diensten van de relevante entiteiten scheiden van de systemen die worden gebruikt voor de ontwikkeling en tests, met inbegrip van back-ups.

6.8.3. De relevante entiteiten evalueren en, waar passend, actualiseren de netwerksegmentatie met geplande tussenpozen en wanneer significante incidenten of significante wijzigingen in activiteiten of risico's plaatsvinden.

6.9. *Bescherming tegen kwaadaardige en ongeoorloofde software*

6.9.1. De relevante entiteiten beschermen hun netwerk- en informatiesystemen tegen kwaadaardige en ongeoorloofde software.

6.9.2. Daartoe implementeren de relevante entiteiten met name maatregelen om het gebruik van kwaadaardige en ongeoorloofde software op te sporen of te voorkomen. De relevante entiteiten zorgen er waar passend voor dat hun netwerk- en informatiesystemen zijn uitgerust met software voor detectie en respons, die regelmatig wordt bijgewerkt overeenkomstig de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling en de contractuele overeenkomsten met de aanbieders.

6.10. Aanpak en openbaarmaking van kwetsbaarheden

- 6.10.1. De relevante entiteiten verkrijgen informatie over technische kwetsbaarheden in hun netwerk- en informatiesystemen, evalueren hun blootstelling aan dergelijke kwetsbaarheden en nemen passende maatregelen om de kwetsbaarheden te beheren.
- 6.10.2. Voor de toepassing van punt 6.10.1 zullen de relevante entiteiten:
- a) de informatie over kwetsbaarheden monitoren via passende kanalen, zoals aankondigingen van CSIRT's, bevoegde autoriteiten, of door leveranciers of dienstverleners verstrekte informatie;
 - b) waar passend kwetsbaarheidsscans uitvoeren en met geplande tussenpozen het bewijs van de resultaten van de scans vastleggen;
 - c) onverwijd kwetsbaarheden aanpakken die door de relevante entiteiten als kritiek voor hun activiteiten zijn aangemerkt;
 - d) ervoor zorgen dat hun aanpak van kwetsbaarheden verenigbaar is met hun procedures voor veranderingsbeheer, beveiligingspatchbeheer, risicobeheer en incidentenbeheer;
 - e) een procedure vaststellen voor de openbaarmaking van kwetsbaarheden overeenkomstig het toepasselijke nationale gecoördineerde beleid inzake openbaarmaking van kwetsbaarheden.
- 6.10.3. Indien de potentiële gevolgen van de kwetsbaarheid dit rechtvaardigen, stellen de relevante entiteiten een plan op en voeren zij dit uit om de kwetsbaarheid te beperken. In andere gevallen documenteren en motiveren de relevante entiteiten de reden waarom de kwetsbaarheid geen herstel vereist.
- 6.10.4. De relevante entiteiten evalueren en, waar passend, actualiseren met geplande tussenpozen de kanalen die zij gebruiken voor het monitoren van de informatie over kwetsbaarheden.

7. **Beleid en procedures om de doeltreffendheid van maatregelen voor het beheer van cyberbeveiligingsrisico's te beoordelen (artikel 21, lid 2, punt f), van Richtlijn (EU) 2022/2555)**

- 7.1. Voor de toepassing van artikel 21, lid 2, punt f), van Richtlijn (EU) 2022/2555 zorgen de relevante entiteiten voor de vaststelling, uitvoering en toepassing van een beleid en procedures om te beoordelen of de maatregelen voor risicobeheer op het gebied van cyberbeveiliging die door de relevante entiteit zijn genomen, doeltreffend worden uitgevoerd en gehandhaafd.
- 7.2. In het beleid en de procedures als bedoeld in punt 7.1 wordt rekening gehouden met de resultaten van de risicobeoordeling overeenkomstig punt 2.1 en met significante incidenten uit het verleden. De relevante entiteiten bepalen:
- a) welke maatregelen voor het beheer van cyberbeveiligingsrisico's moeten worden gemonitord en gemeten, met inbegrip van processen en controles;
 - b) de methoden voor het monitoren, meten, analyseren en evalueren, al naargelang het geval, om te zorgen voor valide resultaten;
 - c) wanneer de monitoring en de meting moeten worden uitgevoerd;
 - d) wie verantwoordelijk is voor het monitoren en meten van de doeltreffendheid van de maatregelen voor het beheer van cyberbeveiligingsrisico's;
 - e) wanneer de resultaten van de monitoring en meting moeten worden geanalyseerd en geëvalueerd;
 - f) wie deze resultaten moet analyseren en evalueren.
- 7.3. De relevante entiteiten evalueren en, waar passend, actualiseren het beleid en de procedures met geplande tussenpozen en bij significante incidenten of significante wijzigingen in activiteiten of risico's.

8. **Basispraktijken op het gebied van cyberhygiëne en opleiding op het gebied van cyberbeveiliging (artikel 21, lid 2, punt g), van Richtlijn (EU) 2022/2555)**

8.1. *Bewustmaking en basispraktijken op het gebied van cyberhygiëne*

8.1.1. Voor de toepassing van artikel 21, lid 2, punt g), van Richtlijn (EU) 2022/2555 zorgen de relevante entiteiten ervoor dat hun werknemers, met inbegrip van leden van bestuursorganen, alsook directe leveranciers en dienstverleners zich bewust zijn van risico's, op de hoogte zijn van het belang van cyberbeveiliging en praktijken op het gebied van cyberhygiëne toepassen.

8.1.2. Voor de toepassing van punt 8.1.1 bieden de relevante entiteiten aan hun werknemers, met inbegrip van leden van bestuursorganen, alsook aan directe leveranciers en dienstverleners, waar passend overeenkomstig punt 5.1.4, een bewustmakingsprogramma aan dat:

- a) op regelmatige tijdstippen wordt gepland, zodat de activiteiten worden herhaald en nieuwe werknemers er ook bij worden betrokken;
- b) wordt vastgesteld in overeenstemming met het beleid inzake netwerk- en informatiebeveiliging, themaspecifieke beleidsmaatregelen en relevante procedures inzake netwerk- en informatiebeveiliging;
- c) informatie bevat over relevante cyberdreigingen, de bestaande maatregelen voor het beheer van cyberbeveiligingsrisico's, contactpunten en middelen voor aanvullende informatie en advies over cyberbeveiligingsaangelegenheden, alsook praktijken op het gebied van cyberhygiëne voor gebruikers.

8.1.3. Het bewustmakingsprogramma wordt, waar passend, getest op doeltreffendheid. Het bewustmakingsprogramma wordt geactualiseerd en op geplande tijdstippen aangeboden, rekening houdend met veranderingen in praktijken op het gebied van cyberhygiëne en het huidige dreigingslandschap en risico's voor de relevante entiteiten.

8.2. *Beveiligingsopleiding*

8.2.1. De relevante entiteiten duiden werknemers aan wier taken vaardigheden en deskundigheid op het gebied van beveiliging vereisen, en zorgen ervoor dat zij regelmatig opleiding krijgen over de beveiliging van netwerk- en informatiesystemen.

8.2.2. De relevante entiteiten dragen zorg voor het opstellen, uitvoeren en toepassen van een opleidingsprogramma in overeenstemming met het beleid inzake netwerk- en informatiebeveiliging, themaspecifieke beleidsmaatregelen en andere relevante procedures inzake netwerk- en informatiebeveiliging, waarin de opleidingsbehoeften voor bepaalde rollen en functies op basis van criteria zijn vastgelegd.

8.2.3. De in punt 8.2.1 bedoelde opleiding moet relevant zijn voor de functie van de werknemer en de doeltreffendheid ervan moet worden beoordeeld. De opleiding moet rekening houden met de bestaande beveiligingsmaatregelen en betrekking hebben op het volgende:

- a) instructies met betrekking tot de veilige configuratie en werking van de netwerk- en informatiesystemen, met inbegrip van mobiele apparaten;
- b) een briefing over bekende cyberdreigingen;
- c) opleiding over het gedrag wanneer zich gebeurtenissen voordoen die relevant zijn voor de beveiliging.

8.2.4. De relevante entiteiten bieden opleiding aan aan personeelsleden die overstappen naar nieuwe functies of rollen die vaardigheden en deskundigheid op beveiligingsgebied vereisen.

8.2.5. Het programma wordt bijgewerkt en op gezette tijden uitgevoerd, rekening houdend met het toepasselijke beleid en de toepasselijke regels, de toegewezen taken, de verantwoordelijkheden, evenals met bekende cyberdreigingen en technologische ontwikkelingen.

9. **Cryptografie (artikel 21, lid 2, punt h), van Richtlijn (EU) 2022/2555)**

9.1. Voor de toepassing van artikel 21, lid 2, punt h), van Richtlijn (EU) 2022/2555 dragen de relevante entiteiten zorg voor het vaststellen, uitvoeren en toepassen van een beleid en procedures met betrekking tot cryptografie, teneinde een adequaat en doeltreffend gebruik van cryptografie te waarborgen ter bescherming van de vertrouwelijkheid, de authenticiteit en de integriteit van gegevens in overeenstemming met het classificatieniveau van de activa van de relevante entiteiten en de resultaten van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling.

- 9.2. In het beleid en de procedures als bedoeld in punt 9.1 wordt het volgende vastgesteld:
- a) in overeenstemming met de classificatie van activa van de relevante entiteiten, het type, de sterkte en de kwaliteit van de cryptografische maatregelen die nodig zijn om de activa van de relevante entiteiten te beschermen, met inbegrip van inactieve gegevens en gegevens in transit;
 - b) op basis van punt a), de vast te stellen protocollen of families van protocollen, alsmede cryptografische algoritmen, versleutelingssterkte, cryptografische oplossingen en gebruikspraktijken die moeten worden goedgekeurd en die vereist zijn voor gebruik in de relevante entiteiten, waar passend volgens een crypto-agility-benadering;
 - c) de benadering van de relevante entiteiten op het gebied van sleutelbeheer, met inbegrip van, waar passend, methoden voor:
 - i) het genereren van verschillende sleutels voor cryptografische systemen en toepassingen;
 - ii) de afgifte en verkrijging van PKI-certificaten;
 - iii) het uitdelen van sleutels aan beoogde entiteiten, met inbegrip van de wijze waarop sleutels bij ontvangst kunnen worden geactiveerd;
 - iv) het opslaan van sleutels, met inbegrip van de wijze waarop geautoriseerde gebruikers toegang krijgen tot sleutels;
 - v) het wijzigen of bijwerken van sleutels, met inbegrip van regels over wanneer en hoe sleutels moeten worden gewijzigd;
 - vi) het omgaan met gecompromitteerde sleutels;
 - vii) het intrekken van sleutels, met inbegrip van het intrekken of deactiveren van sleutels;
 - viii) het maken van een back-up of het archiveren van sleutels;
 - ix) het maken van een back-up of het archiveren van sleutels;
 - x) het vernietigen van sleutels;
 - xi) het bijhouden in logbestanden en controleren van sleutelbeheer-activiteiten;
 - xii) het instellen van activerings- en deactiveringsdata voor sleutels om ervoor te zorgen dat de sleutels alleen gedurende de gespecificeerde periode kunnen worden gebruikt volgens de regels van de organisatie inzake sleutelbeheer.
- 9.3. De relevante entiteiten evalueren en, waar passend, actualiseren hun beleid en procedures met geplande tussenpozen, rekening houdend met de stand van de techniek op het gebied van cryptografie.
10. **Beveiligingsaspecten ten aanzien van personeel (artikel 21, lid 2, punt i), van Richtlijn (EU) 2022/2555)**
- 10.1. *Beveiligingsaspecten ten aanzien van personeel*
- 10.1.1. Voor de toepassing van artikel 21, lid 2, punt i), van Richtlijn (EU) 2022/2555 zorgen de relevante entiteiten ervoor dat hun werknemers en directe leveranciers en dienstverleners, waar van toepassing, hun verantwoordelijkheden op het gebied van beveiliging begrijpen en aanvaarden, voor zover passend voor de aangeboden diensten en de functie en in overeenstemming met het beleid van de relevante entiteiten inzake de beveiliging van netwerk- en informatiesystemen.
- 10.1.2. Het in punt 10.1.1 bedoelde voorschrift omvat het volgende:
- a) mechanismen om ervoor te zorgen dat alle werknemers, directe leveranciers en dienstverleners, indien van toepassing, de standaardpraktijken op het gebied van cyberhygiëne die de relevante entiteiten overeenkomstig punt 8.1 toepassen, begrijpen en volgen;
 - b) mechanismen om ervoor te zorgen dat alle gebruikers met administratieve of bevoorrechte toegang op de hoogte zijn van en handelen in overeenstemming met hun taken, verantwoordelijkheden en bevoegdheden;
 - c) mechanismen om ervoor te zorgen dat de leden van bestuursorganen hun rol, verantwoordelijkheden en bevoegdheden met betrekking tot de beveiliging van netwerk- en informatiesystemen begrijpen en naleven;
 - d) mechanismen voor het aanwerven van voor de respectieve taken gekwalificeerd personeel, zoals referentiecontroles, screeningprocedures, validering van certificaten of schriftelijke tests.
- 10.1.3. De relevante entiteiten evalueren op geplande tijdstippen en ten minste eenmaal per jaar de toewijzing van personeel aan specifieke rollen als bedoeld in punt 1.2, evenals hun verbintenis inzake personeel in dat opzicht. Zij werken de toewijzing indien nodig bij.

10.2. *Verificatie van de achtergrond*

10.2.1. De relevante entiteiten zorgen er binnen de mate van het mogelijke voor dat verificatie van de achtergrond van hun werknemers wordt uitgevoerd en, indien van toepassing, van directe leveranciers en dienstverleners overeenkomstig punt 5.1.4, indien dit noodzakelijk is voor hun rol, verantwoordelijkheden en bevoegdheden.

10.2.2. Voor de toepassing van punt 10.2.1 zullen de relevante entiteiten:

- a) criteria vaststellen die bepalen welke taken, verantwoordelijkheden en bevoegdheden alleen mogen worden uitgeoefend door personen wier achtergrond is geverifieerd;
- b) ervoor zorgen dat de in punt 10.2.1. bedoelde verificatie op deze personen wordt toegepast voordat zij deze taken, verantwoordelijkheden en bevoegdheden gaan uitoefenen, waarbij rekening wordt gehouden met de toepasselijke regeltechnische en ethische eisen in verhouding tot de bedrijfsvereisten, de classificatie van de activa als bedoeld in punt 12.1 en de netwerk- en informatiesystemen waartoe toegang moet worden verkregen, en de waargenomen risico's.

10.2.3. De relevante entiteiten evalueren en, waar passend, actualiseren het beleid met geplande tussenpozen en werken het indien nodig bij.

10.3. *Beëindiging of wijziging van arbeidsprocedures*

10.3.1. De relevante entiteiten zorgen ervoor dat de verantwoordelijkheden en taken op het gebied van netwerk- en informatiebeveiliging die van kracht blijven na beëindiging of wijziging van het dienstverband van hun werknemers, contractueel worden vastgelegd en gehandhaafd.

10.3.2. Voor de toepassing van punt 10.3.1 nemen de relevante entiteiten in de arbeidsvoorwaarden of overeenkomsten van de betrokkene de verantwoordelijkheden en taken op die na de beëindiging van de arbeidsovereenkomst blijven gelden, zoals vertrouwelijkheidsclausules.

10.4. *Tuchtprocedure*

10.4.1. De relevante entiteiten zorgen voor het opzetten, communiceren en onderhouden van een tuchtprocedure voor de behandeling van inbreuken op het beleid inzake netwerk- en informatiebeveiliging. Bij deze procedure wordt rekening gehouden met relevante wettelijke, statutaire, contractuele en zakelijke eisen.

10.4.2. De relevante entiteiten evalueren en, waar passend, actualiseren de tuchtprocedure met geplande tussenpozen en indien nodig vanwege juridische wijzigingen of ingrijpende wijzigingen in activiteiten of risico's.

11. **Toegangscontrole (artikel 21, lid 2, punten i) en j), van Richtlijn (EU) 2022/2555)**

11.1. *Beleid inzake toegangscontrole*

11.1.1. Voor de toepassing van artikel 21, lid 2, punt i), van Richtlijn (EU) 2022/2555 bepalen, documenteren en implementeren de relevante entiteiten een logisch en fysiek toegangscontrolebeleid voor de toegang tot hun netwerk- en informatiesystemen, op basis van bedrijfsvereisten en vereisten inzake de beveiliging van netwerk- en informatiesystemen.

11.1.2. Het in punt 11.1.1 bedoelde beleid:

- a) omvat de toegang van personen, met inbegrip van personeel, bezoekers en externe entiteiten zoals leveranciers en dienstverleners;
- b) omvat de toegang van netwerk- en informatiesystemen;

- c) waarborgt dat alleen toegang wordt verleend aan gebruikers die naar behoren geauthenticeerd zijn.

11.1.3. De relevante entiteiten evalueren en, waar passend, actualiseren het beleid met geplande tussenpozen en wanneer zich significante incidenten of significante wijzigingen in de bedrijfsactiviteiten of risico's voordoen.

11.2. *Beheer van toegangsrechten*

11.2.1. De relevante entiteiten verstrekken, wijzigen, verwijderen en documenteren toegangsrechten tot netwerk- en informatiesystemen overeenkomstig het in punt 11.1 bedoelde beleid inzake toegangscontrole.

11.2.2. De relevante entiteiten:

- a) wijzen toegangsrechten toe en trekken deze in op basis van de beginselen "need-to-know", "least privilege" en scheiding van functies;
- b) zorgen ervoor dat de toegangsrechten bij beëindiging of verandering van baan dienovereenkomstig worden gewijzigd;
- c) zorgen ervoor dat de toegang tot netwerk- en informatiesystemen door de relevante personen wordt toegestaan;
- d) zorgen ervoor dat toegangsrechten op passende wijze betrekking hebben op toegang van derden, zoals bezoekers, leveranciers en dienstverleners, met name door de toegangsrechten te beperken in reikwijdte en duur;
- e) houden een register bij van de verleende toegangsrechten;
- f) loggen het beheer van toegangsrechten.

11.2.3. De relevante entiteiten evalueren de toegangsrechten met geplande tussenpozen en wijzigen deze op basis van organisatorische wijzigingen. De relevante entiteiten documenteren de resultaten van de evaluatie, met inbegrip van de noodzakelijke wijzigingen van de toegangsrechten.

11.3. *Bevoorrechte accounts en systeembeheeraccounts*

11.3.1. De relevante entiteiten voeren een beleid voor het beheer van bevoorrechte accounts en systeembeheeraccounts als onderdeel van het in punt 11.1 bedoelde beleid inzake toegangscontrole.

11.3.2. Het in punt 11.3.1 bedoelde beleid:

- a) omvat sterke identificatie-, authenticatie-, zoals multifactorauthenticatie, en autorisatieprocedures voor bevoorrechte accounts en systeembeheeraccounts;
- b) zet specifieke accounts op die uitsluitend voor systeembeheer worden gebruikt, zoals installatie, configuratie, beheer of onderhoud;
- c) individualiseert en beperkt de voorrechten op het gebied van systeembeheer zoveel mogelijk;
- d) zorgt ervoor dat systeembeheeraccounts alleen worden gebruikt om te verbinden met de systemen voor systeembeheer.

11.3.3. De relevante entiteiten toetsen de toegangsrechten van bevoorrechte accounts en systeembeheeraccounts met geplande tussenpozen, passen deze aan op basis van organisatorische wijzigingen en documenteren de resultaten van de evaluatie, met inbegrip van de noodzakelijke wijzigingen van toegangsrechten.

11.4. *Beheersystemen*

11.4.1. De relevante entiteiten beperken en controleren het gebruik van systemen voor systeembeheer overeenkomstig het in punt 11.1 bedoelde beleid inzake toegangscontrole.

11.4.2. Daartoe zullen de relevante entiteiten:

- a) systemen voor systeembeheer uitsluitend gebruiken voor systeembeheerdoeleinden en niet voor andere activiteiten;
- b) dergelijke systemen logisch scheiden van applicatiesoftware die niet voor systeembeheerdoeleinden wordt gebruikt;
- c) de toegang tot systemen voor systeembeheer beschermen door middel van authenticatie en encryptie.

11.5. *Identificatie*

11.5.1. De relevante entiteiten beheren de volledige levenscyclus van de identiteit van netwerk- en informatiesystemen en hun gebruikers.

11.5.2. Daartoe zullen de relevante entiteiten:

- a) unieke identiteiten creëren voor netwerk- en informatiesystemen en hun gebruikers;
- b) de identiteit van gebruikers aan één persoon koppelen;
- c) toezicht houden op de identiteiten van de netwerk- en informatiesystemen;
- d) het beheer van identiteiten loggen.

11.5.3. De relevante entiteiten staan aan meer personen toegewezen identiteiten, zoals gedeelde identiteiten, alleen toe als die om zakelijke of operationele redenen noodzakelijk zijn en aan een expliciete goedkeuringsprocedure en documentatie onderworpen zijn. De relevante entiteiten houden in het in punt 2.1 bedoelde kader voor het beheer van cyberbeveiligingsrisico's rekening met de aan meer personen toegewezen identiteiten.

11.5.4. De relevante entiteiten evalueren regelmatig de identiteiten van netwerk- en informatiesystemen en de gebruikers ervan en deactiveren deze onverwijld zodra zij niet langer nodig zijn.

11.6. *Authenticatie*

11.6.1. De relevante entiteiten passen beveiligde authenticatieprocedures en -technologieën toe op basis van toegangsbeperkingen en het beleid inzake toegangscontrole.

11.6.2. Daartoe zullen de relevante entiteiten:

- a) ervoor zorgen dat de sterkte van de authenticatie passend is voor de classificatie van het actief waartoe toegang moet worden gekregen;
- b) de toewijzing aan gebruikers en het beheer van geheime authenticatie-informatie controleren door middel van een proces dat de vertrouwelijkheid van de informatie waarborgt, met inbegrip van het adviseren van het personeel over de juiste behandeling van authenticatie-informatie;
- c) in het begin, met vooraf vastgestelde tussenpozen en bij het vermoeden dat de inloggegevens zijn gecompromitteerd, verzoeken om wijziging van de authenticatiegegevens;
- d) eisen dat authenticatiegegevens opnieuw worden ingesteld en gebruikers worden geblokkeerd na een vooraf vastgesteld aantal mislukte inlogpogingen;
- e) inactieve sessies beëindigen na een vooraf bepaalde periode van inactiviteit, en
- f) afzonderlijke gegevens verlangen om toegang te krijgen tot bevoorrechte accounts of beheeraccounts.

11.6.3. De relevante entiteiten gebruiken zoveel mogelijk geavanceerde authenticatiemethoden, in overeenstemming met het oordeel over het bijbehorende risico en de classificatie van het actief waartoe toegang moet worden verkregen, en unieke authenticatie-informatie.

11.6.4. De relevante entiteiten evalueren de authenticatieprocedures en -technologieën met geplande tussenpozen.

11.7. *Multifactorauthenticatie*

11.7.1. De relevante entiteiten zorgen ervoor dat gebruikers worden geauthenticeerd door middel van multifactorauthenticatie of continue authenticatiemechanismen om toegang te krijgen tot de netwerk- en informatiesystemen van de relevante entiteit, waar passend, in overeenstemming met de classificatie van het actief waartoe toegang moet worden verkregen.

11.7.2. De relevante entiteiten zorgen ervoor dat de sterkte van de authenticatie passend is voor de classificatie van het actief waartoe toegang moet worden verkregen.

12. **Beheer van activa (artikel 21, lid 2, punt i), van Richtlijn (EU) 2022/2555)**

12.1. *Classificatie van activa*

12.1.1. Voor de toepassing van artikel 21, lid 2, punt i), van Richtlijn (EU) 2022/2555 stellen de relevante entiteiten classificatieniveaus van alle activa, met inbegrip van informatie, binnen het toepassingsgebied van hun netwerk- en informatiesystemen vast voor het vereiste beschermingsniveau.

12.1.2. Voor de toepassing van punt 12.1.1 zullen de relevante entiteiten:

- a) een systeem van classificatieniveaus voor activa vaststellen;
- b) alle activa verbinden met een classificatieniveau op basis van vereisten inzake vertrouwelijkheid, integriteit, authenticiteit en beschikbaarheid, om de vereiste bescherming aan te geven op basis van hun gevoeligheid, kritieke karakter, risico en bedrijfswaarde;
- c) de beschikbaarheidsvereisten voor de activa afstemmen op de leverings- en hersteldoelstellingen die in hun bedrijfscontinuïteits- en noodvoorzieningsplannen zijn vastgesteld.

12.1.3. De relevante entiteiten verrichten periodieke toetsingen van de classificatieniveaus van activa en werken deze waar passend bij.

12.2. *Behandeling van activa*

12.2.1. De relevante entiteiten zorgen voor de vaststelling, uitvoering en toepassing van een beleid voor de correcte behandeling van activa, met inbegrip van informatie, in overeenstemming met hun beleid inzake netwerk- en informatiebeveiliging, en delen het beleid inzake de passende behandeling van activa mee aan eenieder die activa gebruikt of behandelt.

12.2.2. Het beleid:

- a) bestrijkt de volledige levenscyclus van de activa, met inbegrip van de verwerving, het gebruik, de opslag, het vervoer en de vervreemding;
- b) biedt regels over veilig gebruik, veilige opslag, veilig vervoer en de onherstelbare verwijdering en vernietiging van de activa;
- c) bepaalt dat de overdracht op een veilige manier plaatsvindt, in overeenstemming met het type actief dat wordt overgedragen.

12.2.3. De relevante entiteiten evalueren en, waar passend, actualiseren het beleid met geplande tussenpozen en wanneer zich significante incidenten of significante wijzigingen in de activiteiten of risico's voordoen.

12.3. *Beleid inzake verwijderbare media*

12.3.1. De relevante entiteiten zorgen voor de vaststelling, de uitvoering en de toepassing van een beleid inzake het beheer van verwijderbare opslagmedia en delen dit beleid mee aan hun werknemers en derden die verwijderbare opslagmedia behandelen in de gebouwen van de relevante entiteiten of op andere locaties waar de verwijderbare media verbonden zijn met de netwerk- en informatiesystemen van de relevante entiteiten.

12.3.2. Het beleid:

- a) behelst een technisch verbod op de aansluiting van verwijderbare media, tenzij er een organisatorische reden is voor het gebruik ervan;

- b) regelt de uitschakeling van self-executables vanuit dergelijke media en het scannen van die media op kwaadaardige codes voordat zij in de systemen van de relevante entiteiten worden gebruikt;
- c) biedt maatregelen voor de controle en de bescherming van draagbare opslagapparaten die gegevens in transit en in opslag bevatten;
- d) biedt, waar passend, maatregelen voor het gebruik van cryptografische technieken om gegevens op verwijderbare opslagmedia te beschermen.

12.3.3. De relevante entiteiten evalueren en, waar passend, actualiseren het beleid met geplande tussenpozen en wanneer zich significante incidenten of significante wijzigingen in de activiteiten of risico's voordoen.

12.4. *Inventaris van activa*

12.4.1. De relevante entiteiten stellen een volledige, nauwkeurige, actuele en consistente inventaris van hun activa op en houden deze bij. Zij registreren wijzigingen in de inventarisgegevens op traceerbare wijze.

12.4.2. De granulariteit van de inventaris van activa moet afgestemd zijn op de behoeften van de relevante entiteiten. De inventaris omvat het volgende:

- a) de lijst van verrichtingen en diensten en de beschrijving daarvan;
- b) de lijst van netwerk- en informatiesystemen en andere bijbehorende activa ter ondersteuning van de activiteiten en diensten van de relevante entiteiten.

12.4.3. De relevante entiteiten evalueren en actualiseren de inventaris en hun activa regelmatig en documenteren de geschiedenis van de wijzigingen.

12.5. *Afgeven, teruggeven of verwijderen van activa bij beëindiging van het dienstverband*

De relevante entiteiten dragen zorg voor het vaststellen, het uitvoeren en het toepassen van procedures die waarborgen dat hun activa die onder het gezag van het personeel staan, bij beëindiging van het dienstverband worden afgegeven, teruggegeven of verwijderd, en documenteren het afgeven, teruggeven en verwijderen van die activa. Wanneer het afgeven, teruggeven of verwijderen van activa niet mogelijk is, zorgen de relevante entiteiten ervoor dat de activa geen toegang meer hebben tot de netwerk- en informatiesystemen van de relevante entiteiten in overeenstemming met punt 12.2.2.

13. **Milieu- en fysieke beveiliging (artikel 21, lid 2, punten c), e) en i), van Richtlijn (EU) 2022/2555)**

13.1. *Ondersteunende nutsbedrijven*

13.1.1. Voor de toepassing van artikel 21, lid 2, punt c), van Richtlijn (EU) 2022/2555 voorkomen de relevante entiteiten verlies, beschadiging of compromittering van netwerk- en informatiesystemen of onderbreking van hun activiteiten als gevolg van het falen of de verstoring van ondersteunende nutsvoorzieningen.

13.1.2. Daartoe zorgen de relevante entiteiten, waar passend, voor:

- a) het beschermen van installaties tegen stroomstoringen en andere storingen als gevolg van storingen in ondersteunende nutsvoorzieningen, zoals elektriciteit, telecommunicatie, watervoorziening, gas, riolering, ventilatie en airconditioning;
- b) het eventuele gebruik van redundantie in nutsvoorzieningen;
- c) het beschermen van nutsvoorzieningen voor elektriciteit en telecommunicatie, die gegevens transporteren of netwerk- en informatiesystemen van stroom voorzien, tegen onderschepping en beschadiging;
- d) het monitoren van de in punt c) bedoelde nutsdiensten en het rapporteren aan de bevoegde interne of externe personeelsleden van gebeurtenissen buiten de in punt 13.2.2, b), bedoelde minimum- en maximumcontrole-drempels die van invloed zijn op de nutsdiensten;
- e) het sluiten van contracten voor de noodvoorziening met bijbehorende diensten, zoals de levering van de brandstof voor de noodstroomvoorziening;

- f) de continue doeltreffendheid, de monitoring, het onderhoud en het testen van de stroomvoorziening van de netwerk- en informatiesystemen die nodig zijn voor de werking van de aangeboden dienst, met name de elektriciteits-, temperatuur- en vochtigheidscontrole, en de telecommunicatie- en internetverbinding.
- 13.1.3. De relevante entiteiten testen, evalueren en, waar passend, actualiseren de beschermingsmaatregelen regelmatig of naar aanleiding van significante incidenten of significante wijzigingen in activiteiten of risico's.
- 13.2. *Bescherming tegen fysieke en milieudreigingen*
- 13.2.1. Voor de toepassing van artikel 21, lid 2, punt e), van Richtlijn (EU) 2022/2555 voorkomen of beperken de relevante entiteiten de gevolgen van gebeurtenissen naar aanleiding van fysieke en milieudreigingen, zoals natuurrampen en andere opzettelijke of onopzettelijke bedreigingen, op basis van de resultaten van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling.
- 13.2.2. Daartoe zorgen de relevante entiteiten, waar passend, voor:
- a) het opstellen en uitvoeren van beschermingsmaatregelen tegen fysieke en milieudreigingen;
 - b) het vaststellen van minimum- en maximumcontroledrempels voor fysieke en milieudreigingen;
 - c) het monitoren van milieuparameters en het rapporteren aan de bevoegde interne of externe personeelsleden van gebeurtenissen die buiten de in punt b) bedoelde minimum- en maximumcontroledrempels vallen.
- 13.2.3. De relevante entiteiten testen, evalueren en, waar passend, actualiseren de beschermingsmaatregelen tegen fysieke en milieudreigingen regelmatig of naar aanleiding van significante incidenten of significante wijzigingen in activiteiten of risico's.
- 13.3. *Controle van de perimeter en de fysieke toegang*
- 13.3.1. Voor de toepassing van artikel 21, lid 2, punt i), van Richtlijn (EU) 2022/2555 voorkomen en monitoren de relevante entiteiten ongeoorloofde fysieke toegang tot, beschadiging van en interferentie met hun netwerk- en informatiesystemen.
- 13.3.2. Daartoe zullen de relevante entiteiten:
- a) op basis van de overeenkomstig punt 2.1 uitgevoerde risicobeoordeling beveiligingsperimeters vaststellen en gebruiken ter bescherming van gebieden waar netwerk- en informatiesystemen en andere bijbehorende activa zich bevinden;
 - b) de in punt a) bedoelde gebieden beschermen door middel van passende toegangscontroles en toegangspunten;
 - c) de fysieke beveiliging van kantoren, ruimten en faciliteiten ontwerpen en implementeren;
 - d) hun bedrijfsruimten voortdurend monitoren op ongeoorloofde fysieke toegang.
- 13.3.3. De relevante entiteiten testen, evalueren en, waar passend, actualiseren de fysieke toegangscontrolemaatregelen regelmatig of naar aanleiding van significante incidenten of significante wijzigingen in activiteiten of risico's.